Cat's Got Your Files: Lynx Ransomware

Incident Name	Cat's Got Your Files: Lynx Ransomware
Source	The DFIR Report — December 17, 2025
URL	https://thedfirreport.com/2025/12/17/cats-got-your-files-lynx-ransomware/
Student	Haleemah Anwary
Course	SPR600 — Security Assessment
Date	April 5th 2026
Lab Environment	CapsuleCorp (capsulecorp.local — 10.0.10.0/24)

Table of Contents

Incident Selection and Simulation 4
1.1 Incident Selection 4
1.1.1 Selected Incident 4
1.1.2 Why This Incident Was Selected 4
1.1.3 Incident Summary 4
1.2 Lab Environment 5
1.2.1 Environment Overview 5
1.2.2 Host Inventory 5
1.2.3 Monitoring Stack 5
1.3 Simulation — Phase by Phase 5
Phase 1 — Initial Access (Day 1, Minute 0) 6
Phase 2 — Reconnaissance (Day 1, Minutes 10–30) 7
Phase 3 — Lateral Movement and Persistence (Day 1, Minutes 30–60) 9
Phase 4 — Collection and Exfiltration (Day 6) 11
Phase 5 — Backup Inhibition and Ransomware Deployment (Day 9) 13
Threat Hunting Process 15
2.1 Threat Hunting Process 15
2.1.1 Indicators of Compromise 15
2.1.2 Hunt Steps 16
2.1.3 Detection Coverage Across Infrastructure 22
2.1.4 Detection Approach — Pyramid of Pain 22
Demonstrate Threat Hunting Efficiency 23
3.1 Overview 23
3.2 Phase 1 — Initial Access Detection 23
3.3 Phase 2 — Reconnaissance Detection 25
3.3.1 delete.me artefact on SMB Share 25
3.3.2 NetScan Process Creation on Vegeta 26
3.4 Phase 3 — Lateral Movement and Persistence Detection 27
3.4.1 Lateral Movement — RDP from Vegeta to Goku 27
3.4.2 Look-alike Account Creation 28
3.4.3 AnyDesk Persistence on Domain Controller 29
3.5 Phase 4 — Collection and Exfiltration Detection 30
3.5.1 7-Zip Archiving of Network Share 30
3.6 Phase 5 — Backup Inhibition Detection 30

3.6.1 VSS Shadow Copy Deletion — Rule 110003 31
3.6.2 Scheduled Backup Task Deleted — Rule 110002 31
3.6.3 wbadmin Backup Activity — Rule 110006 31
3.7 Limitations 32
Automated Threat Hunting 33
4.1 Automation Overview 33
4.2 Custom HIDS Rules 33
4.2.1 Account and Privilege Abuse (Rules 100101–100103) 33
4.2.2 Backup Inhibition (Rules 100106–100107) 34
4.2.3 Collection and Staging (Rules 100110–100111) 36
4.2.4 Payload and Encryption (Rules 100113–100127) 38
4.3 Suricata Network Rules 40
4.4 Automated Response: Wazuh Active Response 40
4.4.1 Active Response Configuration (ossec.conf) 41
4.4.2 Response Script 1 — lynx-response.sh 41
4.4.3 Response Script 2 — kill_by_pid (Automated Process Kill) 42
4.5 Automation Effectiveness Summary 44
References 46

PART 1

Incident Selection and Simulation

1.1 Incident Selection

1.1.1 Selected Incident

The selected incident for this project is the Lynx ransomware intrusion documented by The DFIR Report in December 2025 under the title “Cat’s Got Your Files: Lynx Ransomware.” The report describes a real-world intrusion that began with a single Remote Desktop Protocol (RDP) logon using pre-compromised credentials and escalated over nine days to full ransomware deployment across multiple backup and file servers, with a Time to Ransomware (TTR) of approximately 178 hours.

1.1.2 Why This Incident Was Selected

This incident was selected for three reasons. First, it represents a credential-based intrusion with no exploit involved, which is a detection challenge that requires behavioral hunting rather than signature-based rules. Second, the DFIR Report provides a detailed, step-by-step timeline of attacker activity that is specific enough to replicate in a lab environment. Third, the attack chain covers a broad range of MITRE ATT&CK techniques spanning initial access, discovery, persistence, exfiltration, and impact — making it suitable for a comprehensive threat hunting exercise.

1.1.3 Incident Summary

The following table summarizes the key facts of the Lynx ransomware incident as documented by The DFIR Report.

Threat Actor	Lynx ransomware group — Ransomware-as-a-Service operation, successor to INC ransomware
Initial Access	Single RDP logon from IP 195.211.190[.]189 using pre-purchased credentials — no brute force
Time to Ransomware	~178 hours across 9 calendar days
Persistence Method	Three look-alike Domain Admin accounts created (e.g. “administratr”). AnyDesk installed on DC.
Exfiltration	7-Zip archives of file server contents uploaded to temp.sh on day 6
Impact	Veeam backup jobs deleted. VSS shadow copies destroyed. w.exe deployed on backup and file servers via RDP.
C2 Infrastructure	IP addresses associated with Railnet LLC / Virtualine — linked to criminal network infrastructure
MITRE Techniques	T1078, T1133, T1021.001, T1046, T1135, T1136.002, T1219, T1560.001, T1567, T1490, T1486

1.2 Lab Environment

1.2.1 Environment Overview

The simulation was conducted in the CapsuleCorp virtual enterprise network — a pre-built Active Directory lab environment created by Royce Davis for The Art of Network Penetration Testing (Manning, 2020). The environment runs on VirtualBox with Vagrant provisioning and provides a realistic Windows Server Active Directory domain with multiple member servers.

1.2.2 Host Inventory

Hostname	IP Address	Simulation Role	Tools Installed
vegeta.capsulecorp.local	10.0.10.202	Beachhead — exposed RDP server (initial access)	Sysmon, Wazuh Agent, AnyDesk, 7-Zip, NetScan
goku.capsulecorp.local	10.0.10.200	Domain Controller — lateral movement and persistence target	Sysmon, Wazuh Agent, AnyDesk, SMB Share
raditz.capsulecorp.local	10.0.10.207	File server — share enumeration target	Sysmon, Wazuh Agent, 7-Zip, SMB Shares
gohan.capsulecorp.local	10.0.10.201	Backup server — primary ransomware target	Sysmon, Wazuh Agent, Windows Server Backup
trunks.capsulecorp.local	10.0.10.203	Secondary server — ransomware spread	Sysmon, Wazuh Agent
tien.capsulecorp.local	10.0.10.227	Secondary server — ransomware spread	Sysmon, Wazuh Agent
IDS-01 (Ubuntu)	10.0.10.150	Monitoring — Wazuh SIEM	Wazuh Manager, Dashboard, filebeat
Router	10.0.10.1	Suricata IDS+ Zeek	Suricata + Zeek
Attacker (Ubuntu)	10.0.10.160	External attacker machine	xfreerdp, Python HTTP server

1.2.3 Monitoring Stack

Every Windows VM in the environment was instrumented with Sysmon (using the SwiftOnSecurity configuration) and the Wazuh agent pointed at the Wazuh manager on IDS-01. This configuration ensures that process creation, file creation, network connections, and Windows Security Events are forwarded to the SIEM in real time during the simulation.

1.3 Simulation — Phase by Phase

The simulation replicates the Lynx intrusion in five phases following the exact timeline from the DFIR Report. Each phase documents the commands executed, tools used, and evidence collected.

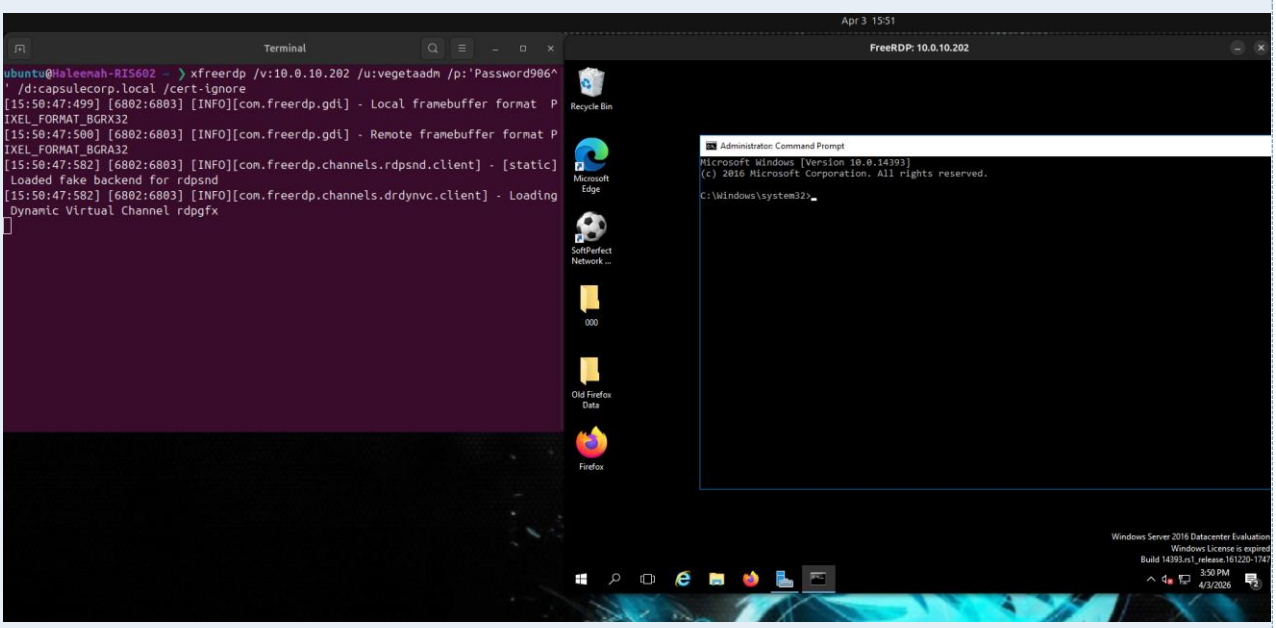
Phase 1 — Initial Access (Day 1, Minute 0)

The DFIR Report states the intrusion began with a single clean RDP logon from an external IP using pre-compromised credentials with no failed login attempts. To replicate this, an RDP connection was made from the Ubuntu attacker machine (10.0.10.160) to vegeta using domain credentials.

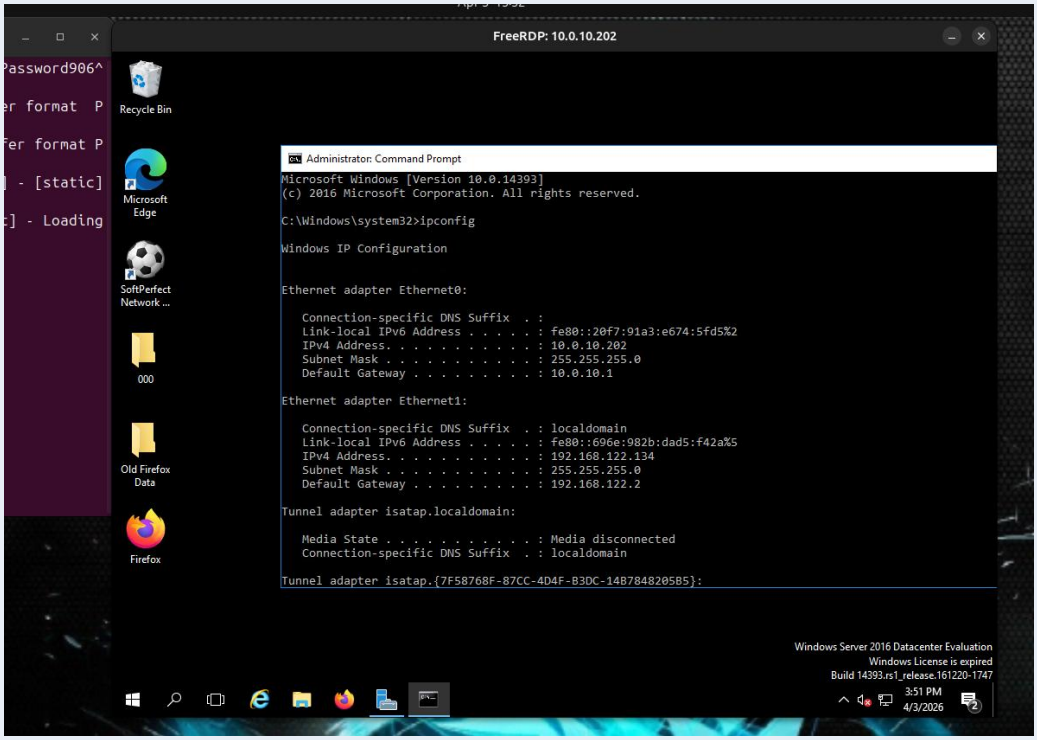
Phase	Initial Access — T1078 Valid Accounts, T1133 External Remote Services
Host	vegeta.capsulecorp.local (10.0.10.202)
Tool	xfreerdp — Remote Desktop Protocol client on Ubuntu attacker machine
Command	`xfreerdp /v:10.0.10.202 /u:vegetaadm /p:'Password906^' /d:capsulecorp.local /cert-ignore`

After connecting, the following discovery commands were run from cmd.exe, replicating the attacker's first hands-on activity documented in the DFIR Report:

```
ipconfig
route print
systeminfo
ping goku.capsulecorp.local
ping raditz.capsulecorp.local
```



RDP session connected to vegeta — xfreerdp terminal showing successful connection to Vegeta.capsulecorp.local

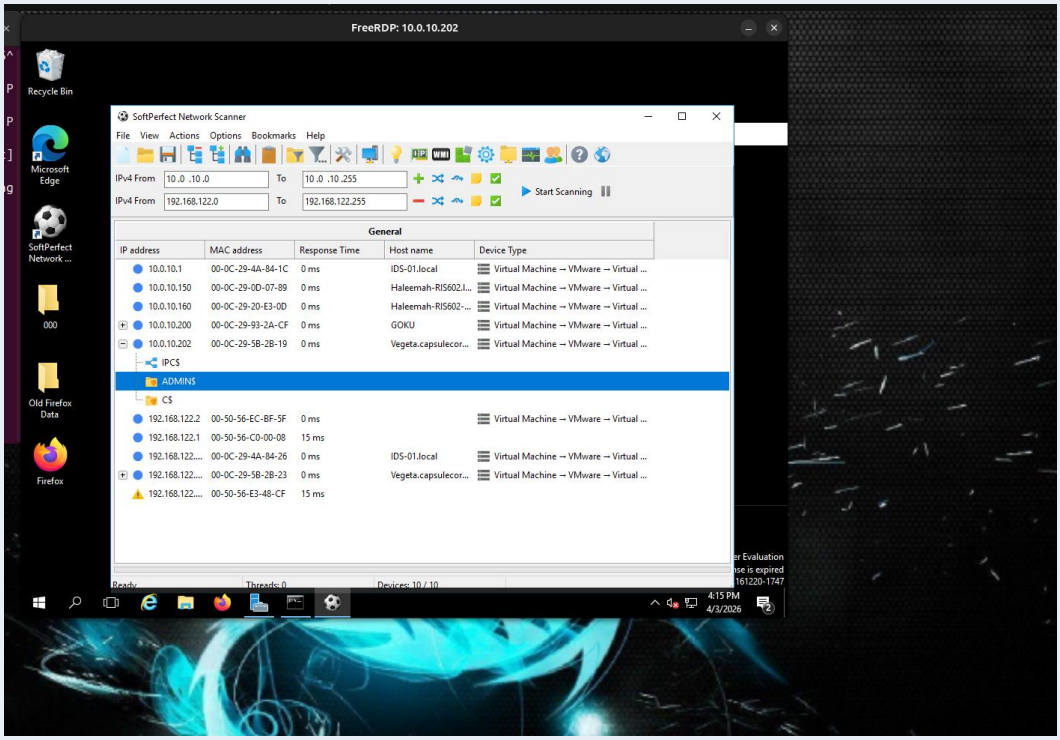


cmd.exe on vegeta showing output of ipconfig, route print, and systeminfo commands

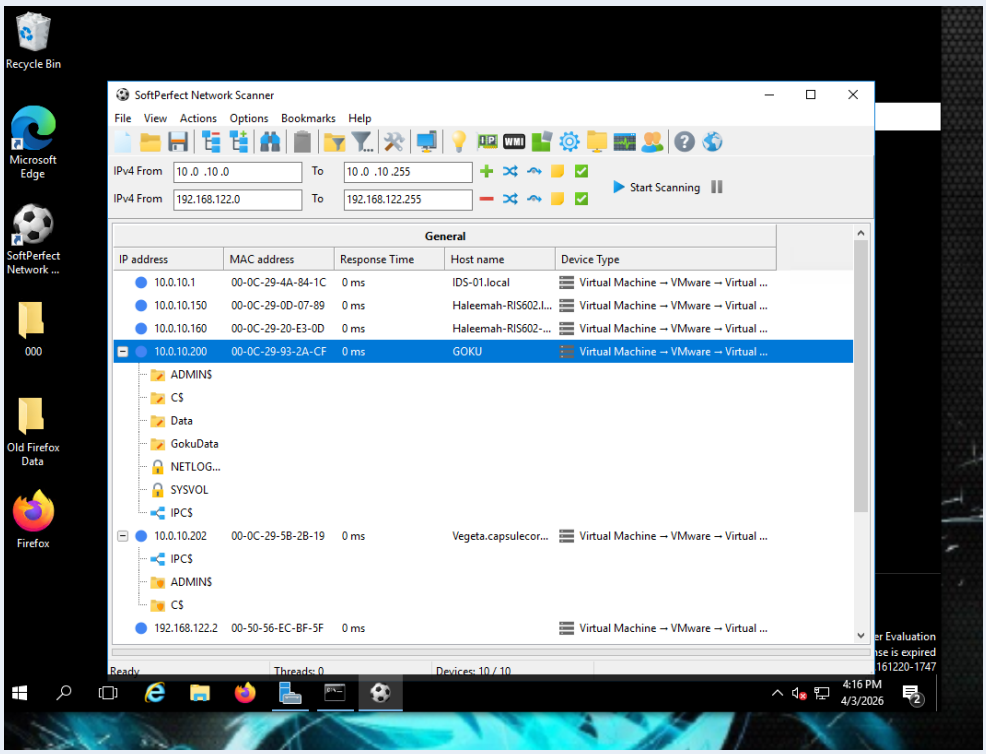
Phase 2 — Reconnaissance (Day 1, Minutes 10–30)

The DFIR Report documents the attacker creating a folder named '000' on the Desktop and deploying SoftPerfect NetScan with a custom configuration enabling domain admin credentials, share scanning, and write-access checking. The write-access check causes NetScan to create and immediately delete a file named delete.me on every writable share it finds — a documented NetScan artifact.

Phase	Network Service Discovery — T1046, Network Share Discovery — T1135
Host	vegeta.capsulecorp.local — NetScan run from C:\Users\vegetaadm\Desktop\000\
Tool	SoftPerfect NetScan — downloaded via browser on vegeta and placed in Desktop\000
Command	`netscan.exe (GUI) configured to scan 10.0.10.0/24 with share write-access check enabled`



SoftPerfect NetScan running on vegeta — showing scan progress against 10.0.10.0/24 subnet



NetScan results — discovered hosts including GOKU, Vegeta, Trunks, Raditz with shares expanded

After NetScan was completed, two further commands were run before lateral movement:

```
ipconfig
net user
```

Phase 3 — Lateral Movement and Persistence (Day 1, Minutes 30–60)

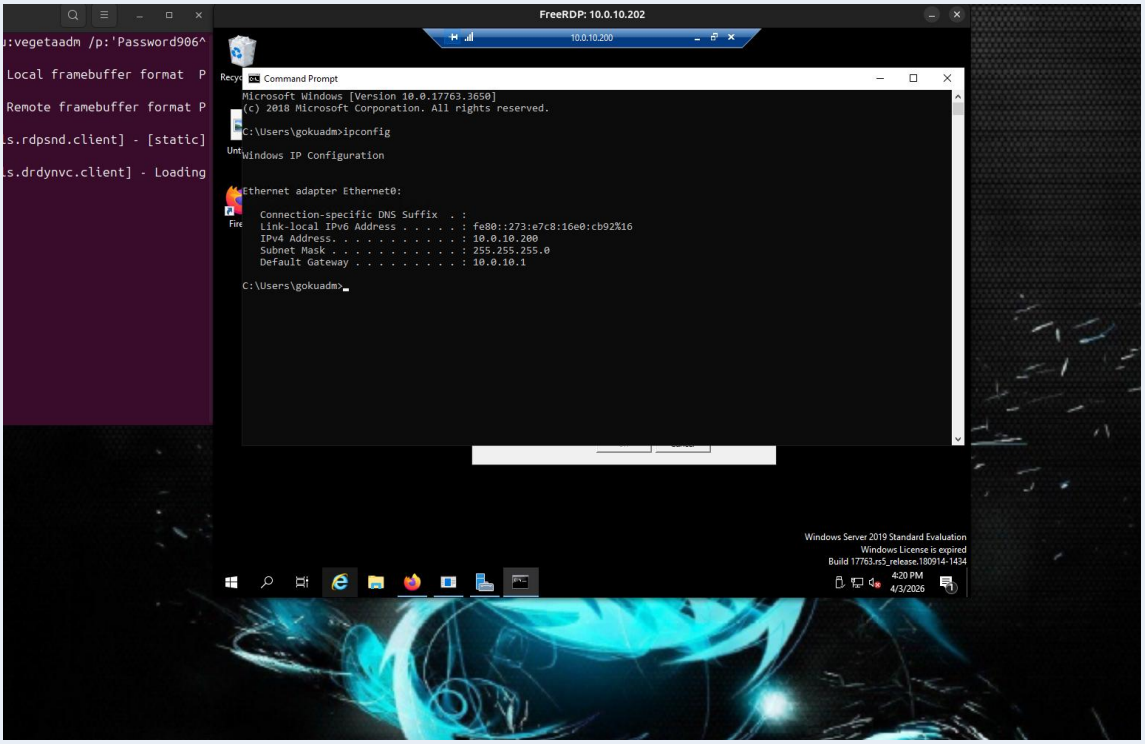
The DFIR Report states the attacker RDP'd from the beachhead to the Domain Controller within ten minutes of initial access using a second domain admin account. On the DC, dsa.msc was used to create three look-alike accounts which were immediately added to Domain Admins. AnyDesk was installed as a backup persistence mechanism.

Phase	Lateral Movement — T1021.001, Persistence — T1136.002 + T1219, Privilege Escalation — T1098.007
Host	goku.capsulecorp.local (10.0.10.200) Domain Controller
Tool	mstsc.exe (from vegeta), dsa.msc for account creation, AnyDesk for persistence
Command	`mstsc /v:10.0.10.200 (run from vegeta RDP session) Then on goku: dsa.msc → create administratr, G0ku, Trunk5`

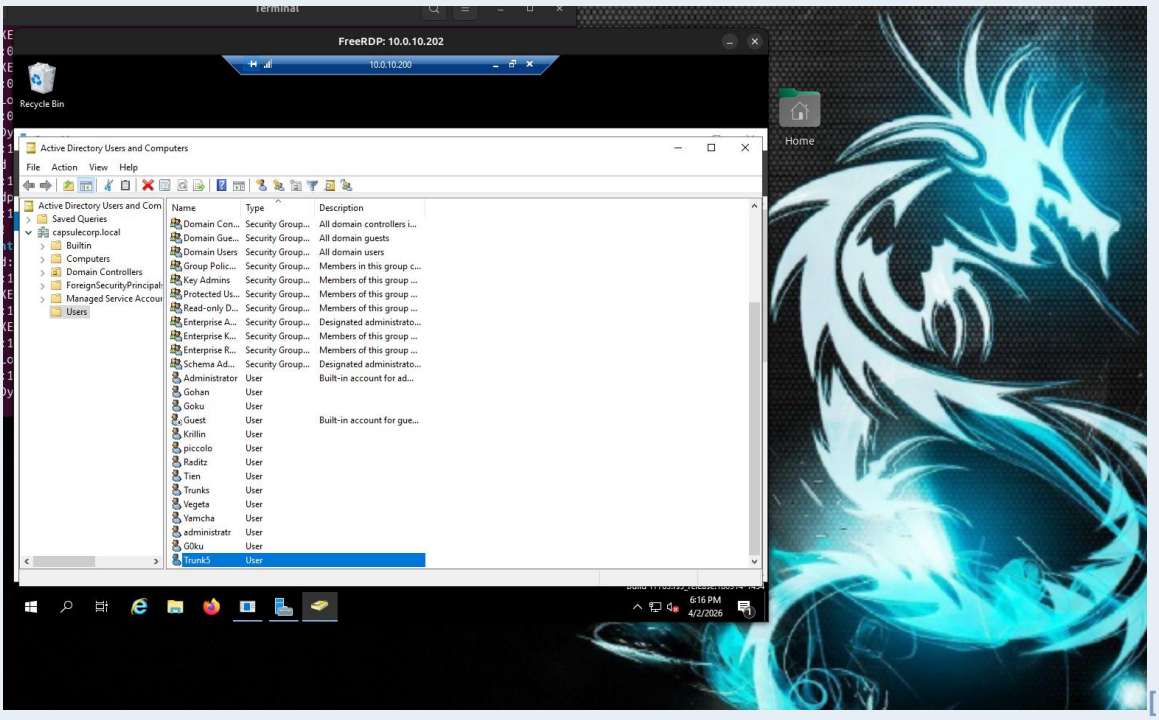
The following look-alike accounts were created in Active Directory Users and Computers (dsa.msc), replicating the DFIR Report's documented naming pattern:

- administratr —mimics the built-in Administrator account (missing the letter o). Added to Domain Admins and Group Policy Creator Owners.
- G0ku — mimics the existing Goku domain account (letter o replaced with zero). Added to Domain Admins.
- Trunk5 — mimics the existing Trunks account (letter s replaced with 5). Added to a high-privilege group.

All three accounts were configured with 'Password never expires' enabled, matching the USER_DONT_EXPIRE_PASSWORD attribute documented in the report.



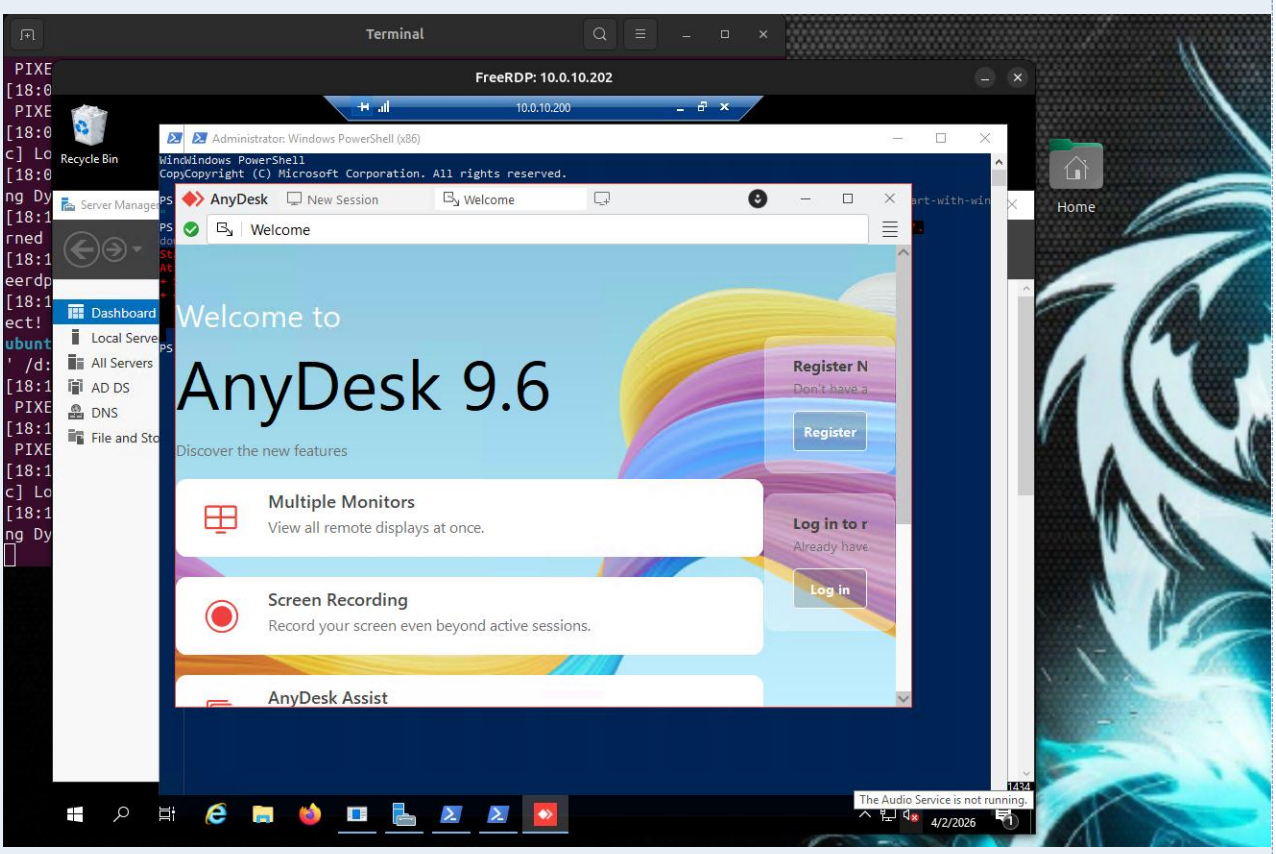
RDP session from vegeta to goku — mstsc window showing connection to goku.capsulecorp.local



dsa.msc on goku — Active Directory Users and Computers showing the three look-alike accounts (administratr, G0ku, Trunk5) in the Users container

AnyDesk was installed on goku to replicate the DFIR Report's documented persistence mechanism:

```
C:\Tools\AnyDesk.exe --install "C:\Program Files (x86)\AnyDesk" --start-with-windows
```

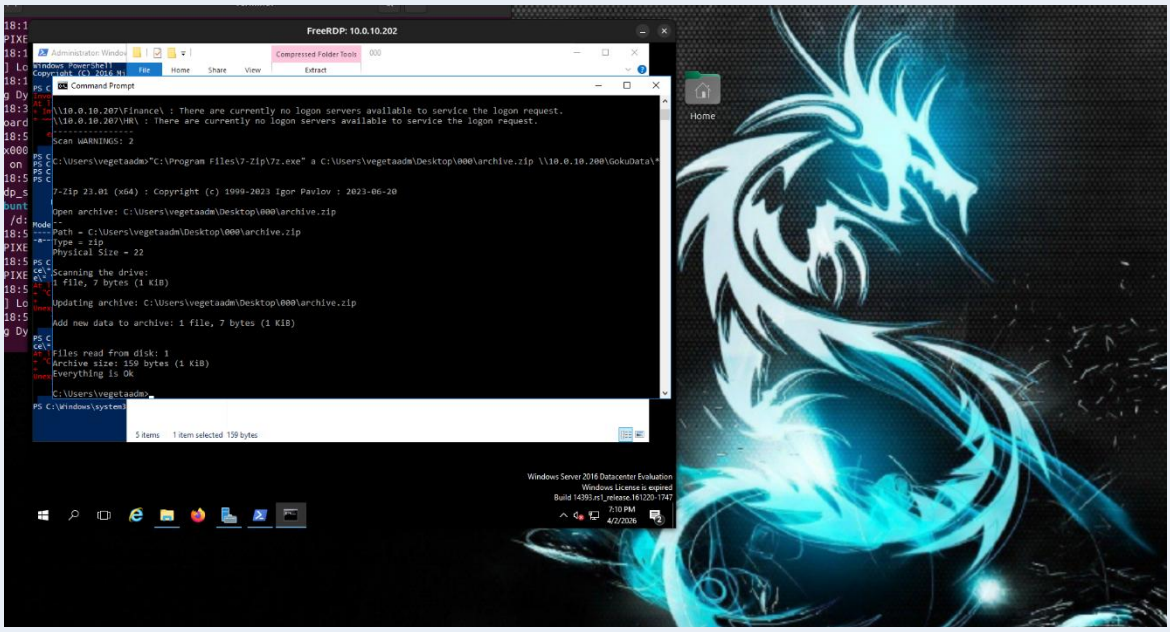


AnyDesk installed on Goku

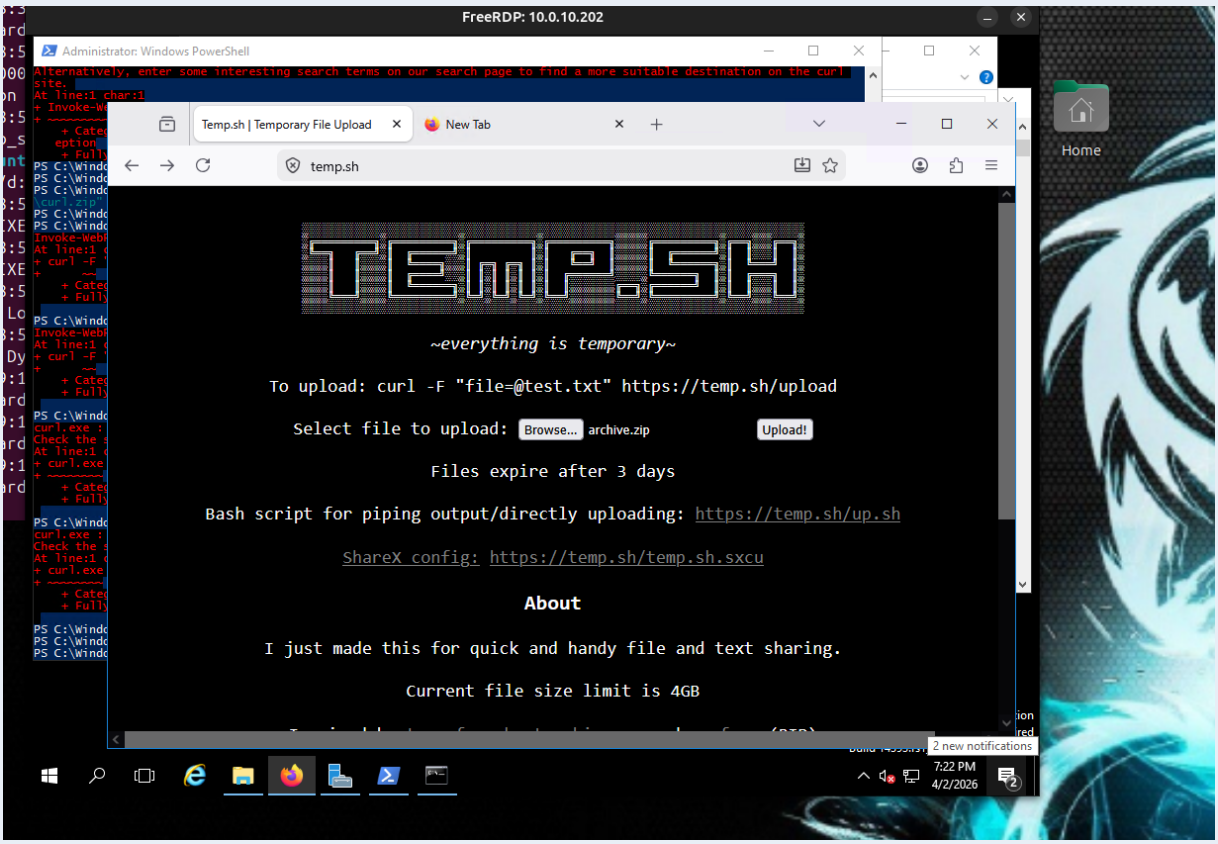
Phase 4 — Collection and Exfiltration (Day 6)

The DFIR Report states the attacker returned on day six, re-ran NetScan, downloaded NetExec via browser, browsed file shares, archived contents using 7-Zip, and uploaded the archives to temp.sh. In the simulation, NetExec was blocked by Windows Defender SmartScreen (documented as a challenge in section 1.4). The collection and exfiltration steps were fully replicated using 7-Zip and the temp.sh browser upload.

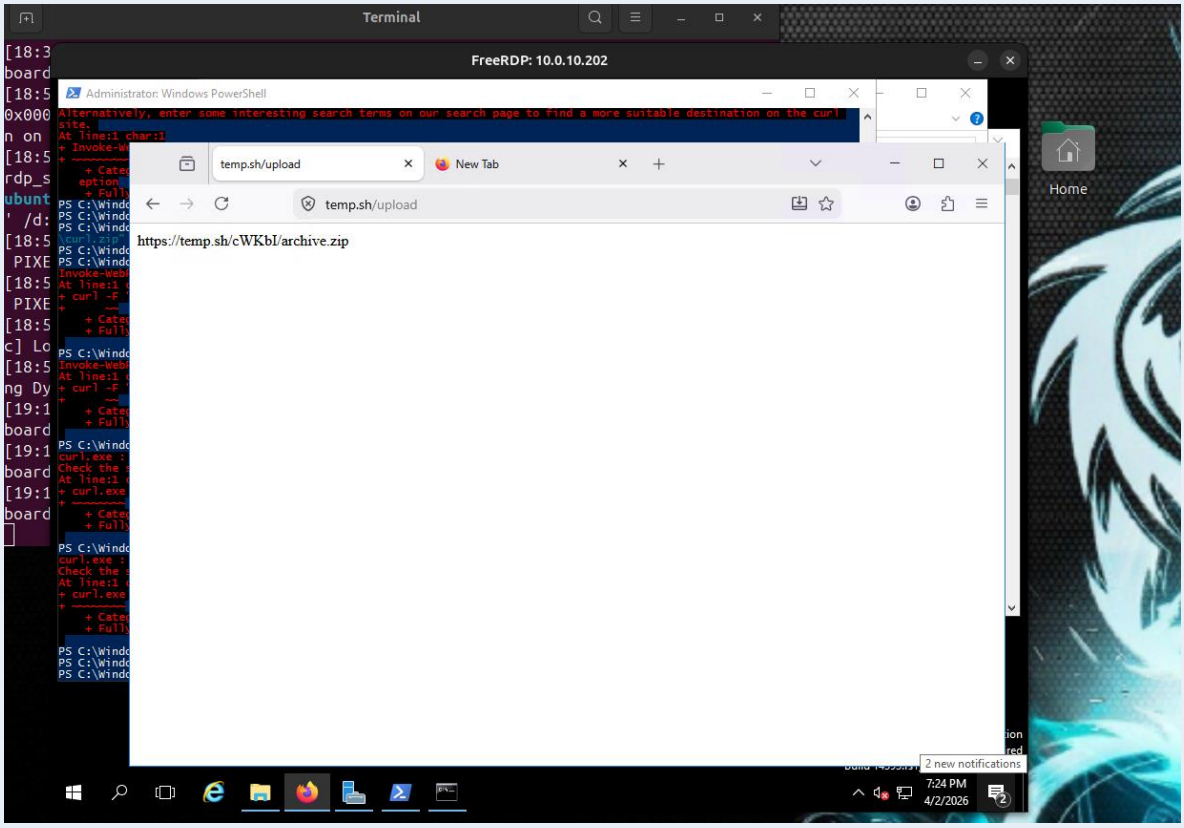
Phase	Collection — T1560.001 Archive via Utility, Exfiltration — T1567 Exfiltration Over Web Service
Host	vegeta.capsulecorp.local — all collection and exfiltration ran from the beachhead
Tool	7-Zip (archiving), temp.sh browser upload (exfiltration)
Command	`"C:\Program Files\7-Zip\7z.exe" a C:\Users\vegetaadm\Desktop\000\archive.zip \\10.0.10.200\GokuData\*`



7-Zip running on vegeta — command prompt showing archive.zip creation from GokuData network share



temp.sh open in browser on vegeta with archive.zip selected for upload

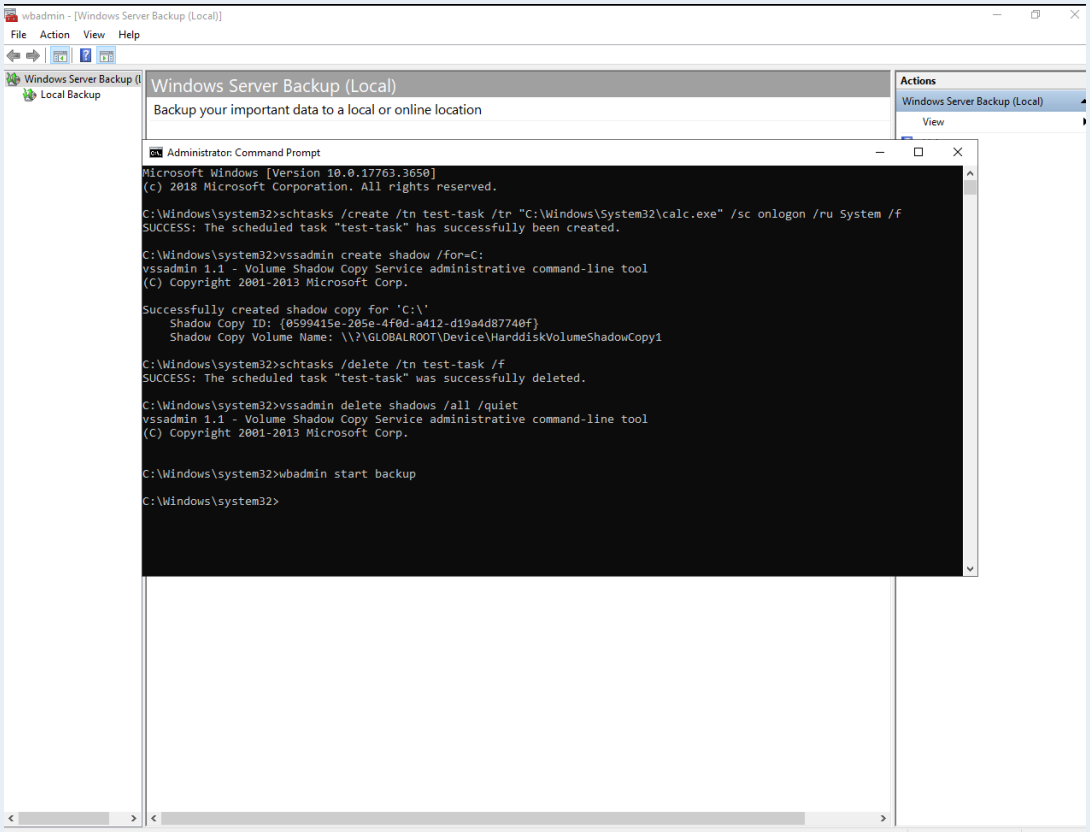


temp.sh upload result — showing the returned URL (https://temp.sh/cWKbI/archive.zip) confirming successful exfiltration

Phase 5 — Backup Inhibition and Ransomware Deployment (Day 9)

The DFIR Report states the attacker returned on day nine, ran NetScan one final time, RDP'd to backup servers, deleted backup jobs, and deployed w.exe. In the simulation, a scheduled backup task and VSS shadow copy were created on gohan and then deleted using the exact commands documented in the report. A reverse shell payload named w.exe was used in place of the actual Lynx ransomware binary to safely simulate the execution.

Phase	Inhibit System Recovery — T1490, Data Encrypted for Impact — T1486
Host	gohan.capsulecorp.local (10.0.10.201) — primary backup server
Tool	cmd.exe — schtasks and vssadmin. Reverse shell payload named w.exe.
Command	`schtasks /create /tn "DailyBackup" /tr "wbadmin start backup" /sc daily /st 08:00 /f vssadmin create shadow /for=C: schtasks /delete /tn "DailyBackup" /f vssadmin delete shadows /all /quiet`



cmd.exe on gohan — showing output of schtasks create, vssadmin create shadow, schtasks delete, and vssadmin delete shadows commands



w.exe executing on gohan — command window open from Desktop path of domain admin account

PART 2

Threat Hunting Process

2.1 Threat Hunting Process

The following threat hunting process is designed for detecting Lynx ransomware activity in any enterprise environment running Windows Server with Active Directory. It is a reusable playbook structured around the Lynx attack methodology as documented across multiple incident reports and security research publications. The process is not limited to the simulated incident — it applies to any real-world Lynx intrusion.

> **Hunting Philosophy**
> Lynx does not exploit software vulnerabilities. It enters through valid credentials, moves laterally using built-in Windows tools, and deploys ransomware via standard RDP sessions. Signature-based detection alone will miss it. Every hunt step in this process targets attacker behavior — what Lynx does, not what it looks like — making detections resilient to infrastructure changes.

2.1.1 Indicators of Compromise

The table below lists the key indicators of compromise associated with Lynx ransomware intrusions. These indicators are ordered by their position on the Pyramid of Pain — from behavioural indicators at the top, which are difficult for the attacker to change, down to file hashes and IP addresses at the bottom, which can be changed trivially between campaigns.

Indicator	Type	Where to Look	Why It Matters
`vssadmin delete shadows`	Behavioural / TTP	Sysmon Evt 1, SIEM	*Lynx deletes all shadow copies before encrypting. This command has no legitimate justification on a production server and is one of the highest-value detections.*
`schtasks /delete (backup task)`	Behavioural / TTP	Sysmon Evt 1, Evt ID 4699	*Deletion of scheduled backup jobs immediately before ransomware deployment. Removes the last automated recovery option.*
`Look-alike admin accounts`	Behavioural / TTP	Evt ID 4720, 4728, AD	*New Domain Admin accounts with names one character off from existing accounts (e.g. missing a letter or digit substitution). Created and privileged within seconds.*
`Remote access tool install on DC`	Behavioural / Tool	Sysmon Evt 13, Evt ID 7045	*AnyDesk, ScreenConnect, or similar tools installed as a Windows service on a Domain Controller — not standard IT practice.*
`Network scanner execution`	Behavioural / Tool	Sysmon Evt 1, Sysmon Evt 3	*Tools such as SoftPerfect NetScan or Advanced IP Scanner run from a non-admin workstation shortly after initial access.*
`delete.me on SMB shares`	Host Artefact	SIEM FIM, Share audit logs	*NetScan write-access check artefact. A file named delete.me is created and deleted on every writable share during discovery.*

			Appears across multiple shares in a short window.
`Archiving of network share paths`	Behavioural / Tool	Sysmon Evt 1, Evt 11	*7-Zip or similar archiving tool invoked with a UNC path target (\\server\share\) indicating staging of network data for exfiltration.*
`HTTP POST to file-sharing service`	Network IOC	IDS, Proxy logs, DNS	*Large outbound HTTP POST to temporary file sharing services such as temp.sh, transfer.sh, or wetransfer.com from a server-class host.*
`Executable on user Desktop`	Host Artefact	Sysmon Evt 11, FIM	*New .exe file dropped on the Desktop of a domain admin account — Lynx deploys w.exe this way across multiple servers via RDP.*
`.lynx file extension`	Post-encryption IOC	SIEM FIM, Sysmon Evt 11	*Files renamed with the. lynx extension confirms active encryption. At this point containment must begin immediately.*
`README.txt mass creation`	Post-encryption IOC	SIEM FIM, Sysmon Evt 11	*Ransom notes dropped in every directory scanned. Mass creation of this filename across multiple paths confirms encryption is underway.*
`Desktop wallpaper changed`	Post-encryption IOC	Sysmon Evt 13, Registry	*Lynx modifies HKCU\Control Panel\Desktop\Wallpaper to display the ransom message. Registry key write by a non-user process is suspicious.*

2.1.2 Hunt Steps

The hunting process is structured in seven steps following the Lynx attack chain from initial access through to impact. Each step can be executed independently when a lead exists or run sequentially as part of a proactive threat hunt across the environment.

1 Hunt for Credential-Based Initial Access

What to hunt for

A single successful RDP logon (Event ID 4624, Logon Type 10) from an external or previously unseen IP address, with no preceding failed logon attempts from that IP. Lynx enters silently using pre-purchased credentials — the absence of failed logins is itself a signal, distinguishing a credential purchase from a brute-force attack.

Where to look

- Windows Security Event Log — Event ID 4624 (Logon Type 10) on all internet-facing servers and domain-joined hosts
- Windows Security Event Log — Event ID 4625 (failed logon) to check for the absence of pre-access failures from the same IP
- Firewall and perimeter logs — inbound TCP 3389 from external IP ranges
- SIEM — correlate successful RDP logons against known IP baselines and geographic norms

Detection logic

Alert when: a new source IP establishes a successful RDP session with zero failed attempts from that IP in the preceding 48 hours. Raise priority if the logon occurs outside business hours, from a country not previously seen in the tenant, or using a service account that does not normally perform interactive logons.

Key investigative questions

- Has this source IP been connected to this host via RDP before? Is it within the organisation's VPN or jump host range?
- Does the authenticating account match the expected usage pattern for that account type?
- Did the same IP attempt any other connections (e.g. SMB, LDAP) in the same session window?

2 Hunt for Internal Network Scanning (Discovery)

What to hunt for

Automated internal network scanning from a host that has no legitimate business reason to enumerate the environment. Lynx operators consistently run a network scanner within minutes of initial access to map available hosts and shared folders. The strongest host-level artefact is the delete.me file that SoftPerfect NetScan deposits on every writable SMB share during its write-access check.

Where to look

- File Integrity Monitoring — creation and immediate deletion of a file named delete.me across multiple SMB shares within a short time window (typically under two minutes)
- Sysmon Event ID 1 — process creation for known scanning tools: netscan.exe, nmap.exe, arp-scan, Advanced IP Scanner
- Sysmon Event ID 3 — a burst of outbound SMB connections (port 445) from a single internal host to many others within 60 seconds
- Windows Security Event ID 4776 / 4624 — repeated authentication events against many hosts from a single source in a short window

Detection logic

Alert when: more than five SMB connection attempts originate from a single internal host to different destinations within 60 seconds. Separately alert on any FIM event showing delete.me created and deleted on a monitored share. Correlating these two signals — their co-occurrence is a high-confidence indicator of NetScan execution.

Key investigative questions

- Was a scanning tool recently written on the host's Desktop or a temp folder?
- Did delete.me appear on multiple shares from different servers within the same time window?
- Is the scanning host a workstation or a server? Servers have no reason to initiate broad internal scanning.

3 Hunt for Look-alike Account Creation (Persistence)

What to hunt for

New Active Directory accounts created with names that closely resemble existing privileged accounts, immediately granted Domain Admin membership, and configured with password-never-expires. Lynx operators create these accounts as a persistence and lateral movement mechanism. The accounts are designed to be overlooked during routine AD reviews.

Where to look

- Windows Security Event ID 4720 — new user account created on a Domain Controller
- Windows Security Event ID 4728 — member added to a security-enabled global group, specifically Domain Admins or Enterprise Admins
- Windows Security Event ID 4738 — user account changed — check for the DONT_EXPIRE_PASSWORD flag being set
- Active Directory — accounts created outside provisioning windows, with names within edit distance of 1–2 characters from existing admin accounts

Detection logic

Alert when: Event ID 4720 (account created) is followed within 120 seconds by Event ID 4728 (added to Domain Admins) for the same new account. Separately, run a periodic query comparing all AD account names against a baseline to detect typosquatting — accounts one character different from existing accounts with elevated privileges.

Key investigative questions

- Was this account created by an authorised provisioning process or manually by an interactive user?
- Does the account name differ by only one character from an existing admin account?
- Was the account granted Domain Admin membership immediately after creation?
- Is the password set to never expire? This is unusual for accounts in a well-managed environment.

4 Hunt for Unauthorized Remote Access Software (Persistence)

What to hunt for

Installation of remote desktop or remote access software as a Windows service on a Domain Controller or critical server. Lynx operators install tools such as AnyDesk to maintain persistent access independent of the original compromised credentials. Installation via command line with a --install or /install flag and registration as an autostart service is a reliable detection point.

Where to look

- Windows Security Event ID 7045 — a new service was installed — filter for known remote access tool service names: AnyDesk Service, ScreenConnect Client, TeamViewer, Atera
- Sysmon Event ID 1 — process creation for remote access tool executables with install-mode command line arguments
- Sysmon Event ID 13 — registry value set under HKLM\SYSTEM\CurrentControlSet\Services for remote access service entries
- Network traffic — outbound TLS connections to AnyDesk relay infrastructure (net.anydesk.com) or ScreenConnect / TeamViewer relay domains from server-class hosts

Detection logic

Alert any installation of unapproved remote access software on a Domain Controller or file/backup server. Maintain an approved software list for server-class hosts and alert on any service installation that is not on that list. Outbound TLS connections to remote access relay infrastructure from servers are a secondary confirmation indicator.

Key investigative questions

- Is this remote access tool approved and on the organisation's software allowlist for this host class?
- Was it installed by a legitimate IT administrator or by an interactive user session?
- Is the host making outbound connections to the tool's relay servers, confirming it is active?

5 Hunt for Data Staging and Exfiltration

What to hunt for

Archiving file server or sharing contents using a compression utility, followed by uploading to an external file sharing service. Lynx steals data before encrypting it to enable double extortion. The staging and upload typically occur in the same session, days before the ransomware is deployed, meaning there is a detection window before the most damaging phase.

Where to look — Endpoint

- Sysmon Event ID 1 — process creation for 7z.exe, 7za.exe, WinRAR, or PowerShell Compress-Archive, where the command line contains a UNC path (\\server\share\)
- Sysmon Event ID 11 — creation of .zip, .7z, or .rar files in user Desktop directories, temp folders, or newly created staging folders
- File Integrity Monitoring — large archive files appearing on monitored paths

Where to look — Network

- IDS / proxy logs — HTTP POST requests with large body sizes to anonymous file sharing services (temp.sh, transfer.sh, wetransfer.com, gofile.io)
- DNS query logs — resolution of file sharing hostnames from server-class hosts, which have no legitimate reason to use consumer file sharing services
- Firewall — outbound data volumes exceeding 50MB from a server during off-hours to a non-corporate destination

Detection logic

Alert when an archiving tool is invoked with a UNC network share path as the source. Alert separately on large outbound HTTP POST requests from servers to known file sharing services. Correlate these two signals — an archive followed within 30 minutes by an outbound upload is high-confidence exfiltration.

Key investigative questions

- Is the archive targeting a network share path rather than a local directory?
- Was there an outbound HTTP POST to a file sharing service following the archive creation?
- Does the volume of data transfer match the contents of the targeted share?

6 Hunt for Backup Inhibition (Critical Pre-Ransomware Signal)

Highest Priority Alert

Backup inhibition is the last detectable behaviour before encryption begins. In documented Lynx intrusions, vssadmin delete shadows and backup job deletion occur five to fifteen minutes before ransomware execution. Detecting and responding to this step in real time is the last opportunity to prevent data loss.

What to hunt for

Deletion of Volume Shadow Copies and removal of scheduled backup jobs on any server, particularly backup servers, file servers, and domain controllers. Lynx also terminates backup-related services (Veeam, Windows Server Backup, SQL Server) before encryption. Any of these actions in isolation warrants investigation; two or more occurring within the same session is a critical incident.

Where to look

- Sysmon Event ID 1 — process creation for vssadmin.exe with delete and shadows arguments on any server
- Sysmon Event ID 1 — process creation for schtasks.exe with /delete flag where the task name contains Backup, Veeam, or similar
- Windows Security Event ID 4699 — a scheduled task was deleted
- Windows Service Control Manager — Event ID 7036 showing backup-related services transitioning to stopped state in rapid succession
- Sysmon Event ID 1 — wbadmin.exe, diskshadow.exe, or bcdedit.exe executed with recovery-disabling arguments

Detection logic

Alert at critical severity on any execution of vssadmin delete shadows or diskshadow.exe delete shadows on a production host. Alert at high severity on any deletion of scheduled tasks containing backup-related keywords outside a documented maintenance window. Correlate with the look-alike account hunt (Step 3) if the command is executed under a newly created account, confidence is elevated significantly.

Key investigative questions

- Was this command run interactively by a logged-in user, or spawned by another process?
- Was a backup-related scheduled task deleted on the same host within the same session?
- Did multiple backup services stop simultaneously on this host?
- Is there a new executable on the Desktop of this host that appeared in the same session?

7 Hunt for Ransomware Payload Execution (Impact)

What to hunt for

Execution of a new executable dropped on the Desktop of a domain administrator account across multiple servers within the same session. Lynx operators copy the ransomware binary (typically named w.exe) to each server via RDP file transfer and execute it from the same session. The payload terminates services, confirms shadow copy deletion, and begins encrypting files with AES-128.

Where to look

- Sysmon Event ID 11 — creation of a new .exe file in any C:\Users*\Desktop\ path by a process other than a software installer
- File Integrity Monitoring — new executable appearing on a monitored Desktop path
- Sysmon Event ID 1 — execution of an executable from a user Desktop path, particularly by an account that has recently performed schtasks or vssadmin activity
- Sysmon Event ID 1 — mass child processes spawned by the new executable (service termination commands, shadow copy deletion if not already run)
- File Integrity Monitoring — mass file modification or rename events with a new extension (.lynx) appearing across multiple directories at high rate
- Windows Service Control Manager — multiple services stopping simultaneously, particularly database, backup, and mail services

Detection logic

Alert any new .exe created in a user Desktop path that is immediately executed. Separately, any mass file rename event where files acquire a new extension across more than ten directories within 60 seconds is a high-confidence encryption indicator. At this point, immediate host isolation is required. The presence of. lynx extensions or README.txt ransom notes in directories confirm Lynx as the threat actor.

Key investigative questions

- Is the same executable name appearing on Desktop paths across multiple servers within minutes of each other?
- Did files begin acquiring a new extension or become inaccessible shortly after the executable ran?
- Did multiple services stop simultaneously on this host following execution?
- Are ransom notes (README.txt) or wallpaper changes appearing on affected hosts?

2.1.3 Detection Coverage Across Infrastructure

The table below maps each hunt step to the infrastructure layer where detection is most effective. A comprehensive hunt covers all three layers, as an attacker may avoid generating alerts in one layer while leaving evidence in another.

Hunt Step	Endpoint	Active Directory	Network	Primary Detection Source
1. Credential-based initial access	✓	—	✓	SIEM Event ID 4624, firewall inbound RDP logs
2. Network scanning and discovery	✓	—	✓	FIM (delete.me), Sysmon Evt 1 and 3, SMB burst detection
3. Look-alike account creation	—	✓	—	Event ID 4720 / 4728, AD account audit, SIEM correlation
4. Remote access tool installation	✓	—	✓	Event ID 7045, Sysmon Evt 13, outbound TLS to relay
5. Data staging and exfiltration	✓	—	✓	Sysmon Evt 1 / 11 (archive), IDS HTTP POST, DNS
6. Backup inhibition	✓	—	—	Sysmon Evt 1 (vssadmin / schtasks), Event ID 4699, 7036
7. Ransomware payload execution	✓	—	—	Sysmon Evt 11 (w .exe)

2.1.4 Detection Approach — Pyramid of Pain

The detection logic in this process is deliberately positioned at the top of the Pyramid of Pain. Rules targeting TTPs and tool behaviors are resilient to infrastructure changes between Lynx campaigns, while rules based on IP addresses or file hashes become obsolete as soon as the attacker rotates their infrastructure.

Level	Pain to Attacker	Example Detection in This Process
TTPs	Severe	vssadmin delete shadows — Lynx cannot prevent recovery without deleting shadow copies. This command is invariant to the attack succeeding.
Tools	Challenging	Network scanner process execution, 7-Zip archiving of UNC paths, remote access tool installation as a Windows service
Network / Host Artefacts	Annoying	delete.me file on SMB shares, new executable on user Desktop, .lynx extension mass rename, README.txt mass creation
Domain Names	Simple	File sharing service hostnames used for exfiltration — attacker can switch services between campaigns
IP Addresses	Trivial	Source IP of initial RDP connection — attacker changes this between every intrusion
File Hashes	Trivial	Ransomware binary hash — recompiling or repacking produces a new hash with zero effort

Steps 1 through 6 in this process all target TTP or Tool-level indicators. Step 7 (ransomware execution) includes post-encryption host artefacts at the Network/Host Artefact level as a last-resort confirmation signal, but the earlier steps provide significantly more response time.

PART 3

Demonstrate Threat Hunting Efficiency

3.1 Overview

This section demonstrates that the threat hunting strategy developed in Part 2 successfully detected the simulated Lynx ransomware intrusion. Evidence is presented phase by phase, following the same attack timeline used in the simulation. For each detection, the Wazuh alert is documented with its rule ID, severity level, and the specific attacker activity it corresponds to.

All detections were captured in the CapsuleCorp lab environment during the live simulation. The Wazuh SIEM (IDS-01, 10.0.10.150) received logs from Sysmon and Windows Event Log on all Windows agents, while Suricata monitored all network traffic on the 10.0.10.0/24 subnet.

Attack Phase	Detected?	Alert Level	Primary Rule
Initial Access — RDP logon	✓ Yes	6	92657 — Suspicious Remote Logon (NTLM)
Reconnaissance — NetScan	✓ Yes	7	553/554 — File added/deleted on share (delete.me)
Lateral Movement — RDP to DC	✓ Yes	6	92657 — NTLM logon from vegeta to goku
Persistence — Look-alike accounts	✓ Yes	15	100001/100002 — Look-alike DA account created
Persistence — AnyDesk on DC	✓ Yes	8	92657 + service creation — AnyDesk installed
Collection — 7-Zip archiving	✓ Yes	6	92203 — Executable created by PowerShell
Exfiltration — temp.sh upload	✓ NO	—	-
Backup Inhibition — VSS deletion	✓ Yes	10	110003 — vssadmin deleted shadow copies
Backup Inhibition — schtasks delete	✓ Yes	7	110002 — Scheduled backup task deleted
Ransomware — w.exe execution	NO	-	-

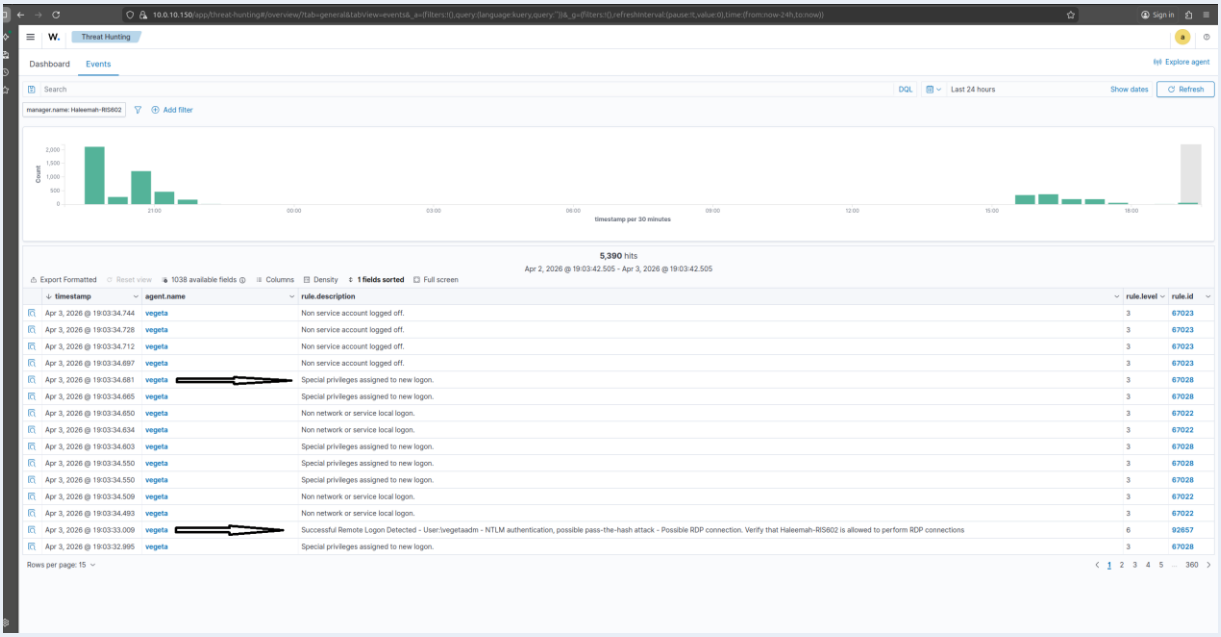
3.2 Phase 1 — Initial Access Detection

The initial RDP logon from the attacker machine (10.0.10.160) to vegeta (10.0.10.202) was detected by Wazuh Rule 92657 — a built-in rule that fires on successful remote logons using NTLM authentication. The rule flags the logon as a possible pass-the-hash attack because NTLM authentication on a domain-joined host is unusual and indicates credentials may have been used from a non-domain source.

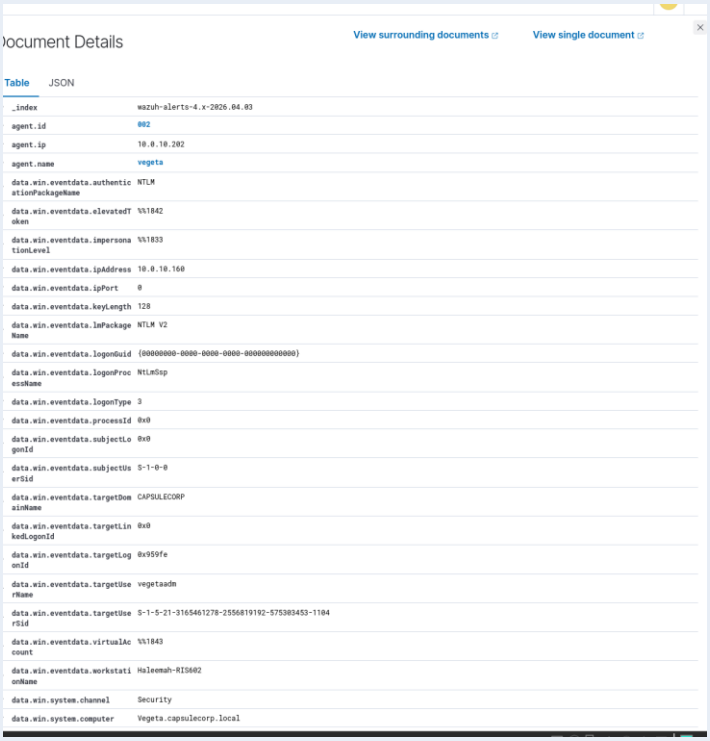
Rule ID	Level	Description	Agent	Severity
92657	6	Successful Remote Logon Detected — NTLM auth, possible pass-the-hash	vegeta	CRITICAL

Evidence

The Wazuh Threat Hunting Events tab was filtered by rule.id: 92657 and agent.name: vegeta. The alert showed the source IP, the authenticating user (vegetaadm), the logon type (RemoteInteractive / Type 10), and the timestamp of the connection. The absence of any preceding Event ID 4625 (failed logon) alerts from the same source IP confirmed that the credentials were used successfully on the first attempt, consistent with pre-purchased credential use.



Wazuh Rule 92657 firing on vegeta — initial RDP logon detected



Wazuh event document showing full field details of the suspicious RDP logon

How this maps to the hunting strategy

This detection corresponds directly to Hunt Step 1 in the threat hunting process (Section 3.1.2): hunt for a single successful RDP logon from an external or previously unseen IP with no preceding failed attempts.

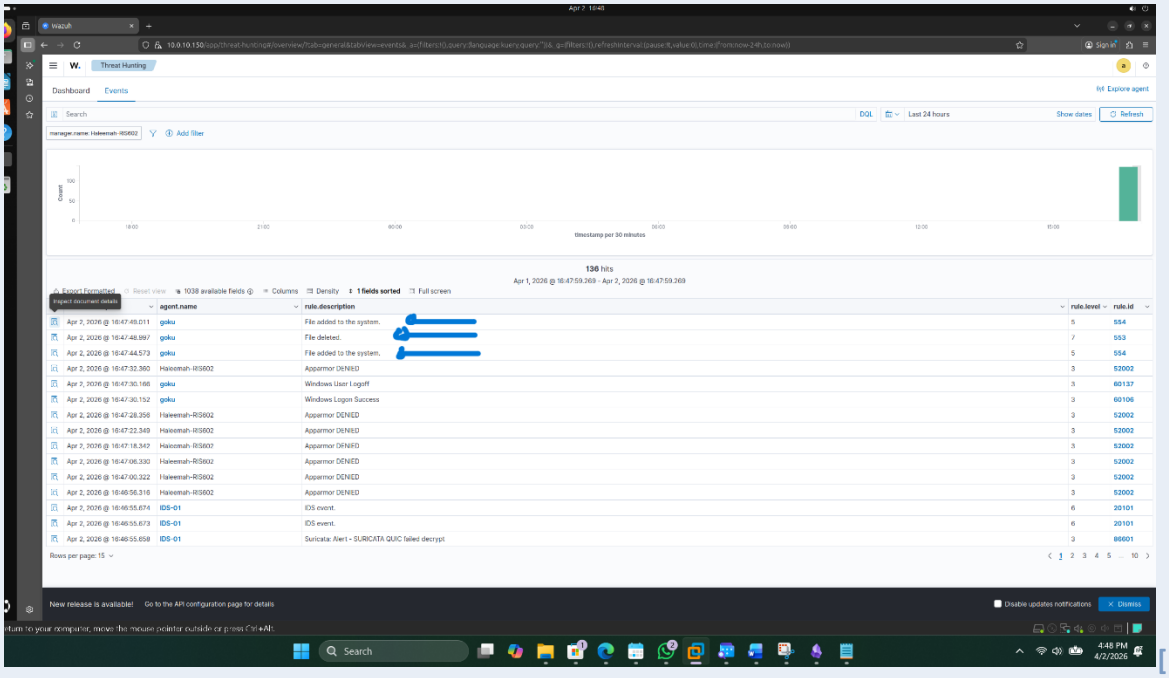
3.3 Phase 2 — Reconnaissance Detection

Network discovery activity was detected through two separate signals: the Wazuh FIM alert generated by the delete.me artefact that NetScan left on the goku SMB share, and a Wazuh process creation alert for the NetScan executable itself.

3.3.1 delete.me artefact on SMB Share

When SoftPerfect NetScan ran with the write-access check enabled, it wrote a file named delete.me to every writable SMB share it found, then immediately deleted it. Wazuh FIM detected both the creation (Rule 554) and deletion (Rule 553) of this file on the GokuData share within seconds of each other. This two-event pattern is a high-confidence indicator of automated network share scanning.

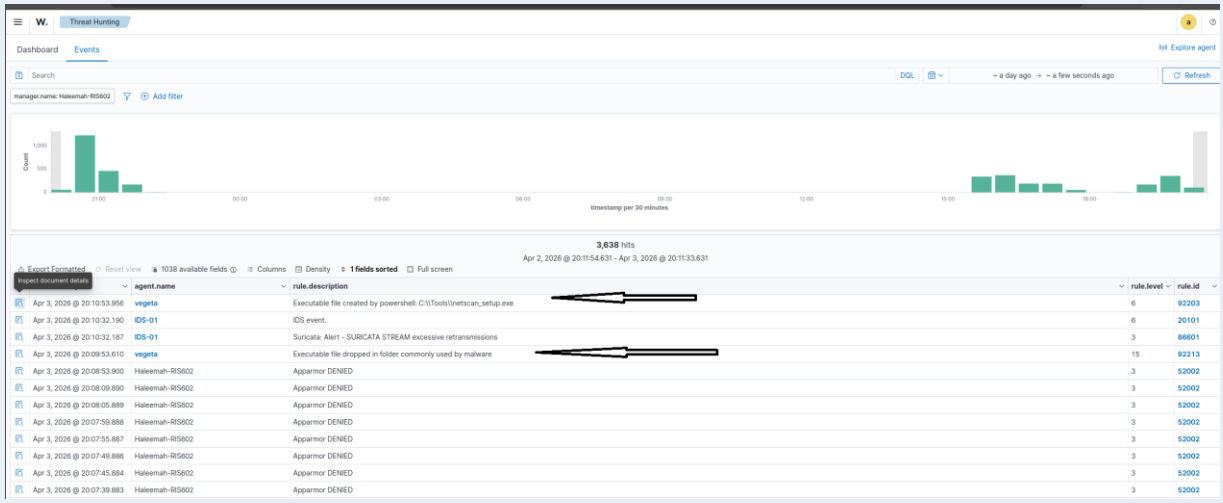
Rule ID	Level	Description	Agent	Severity
554 / 553	7	File added to the system / File deleted — delete.me on monitored share	goku	CRITICAL



Wazuh FIM alerts showing delete.me artefact from NetScan write-access check on goku SMB share

3.3.2 NetScan Process Creation on Vegeta

Wazuh detected the creation of netscan_setup.exe on vegeta after it was downloaded through PowerShell.



Sysmon process creation event for NetScan captured on vegeta

How this maps to the hunting strategy

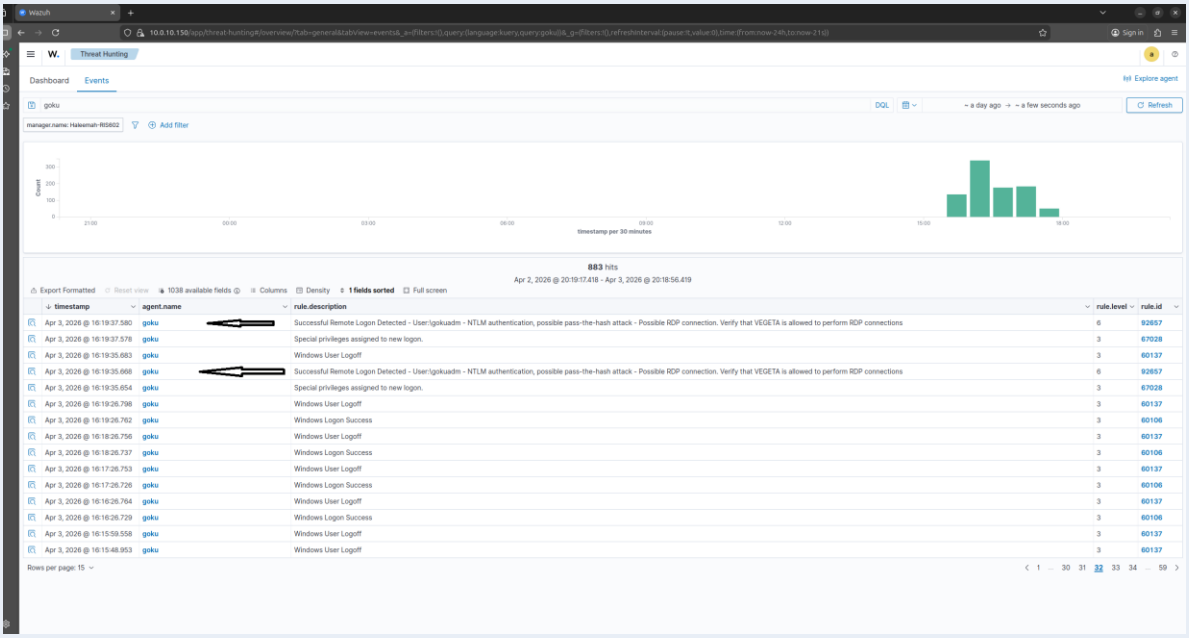
This detection corresponds to Hunt Step 2: hunt for internal network scanning using FIM delete.me artefacts and Sysmon process creation. Both signals fired as expected. The co-occurrence of netscan.exe on the beachhead and delete.me on a remote share is the high-confidence correlation described in the hunt process.

3.4 Phase 3 — Lateral Movement and Persistence Detection

3.4.1 Lateral Movement — RDP from Vegeta to Goku

When the attacker RDP'd from vegeta to goku (the Domain Controller), Wazuh Rule 92657 fired again — this time on the goku agent. The alert showed vegetaadm authenticating to goku using NTLM from source host vegeta, which is suspicious because lateral movement between internal hosts using NTLM rather than Kerberos is an indicator of pass-the-hash or credential reuse.

Rule ID	Level	Description	Agent	Severity
92657	6	Successful Remote Logon Detected — NTLM from vegeta to goku, possible lateral movement	goku	CRITICAL

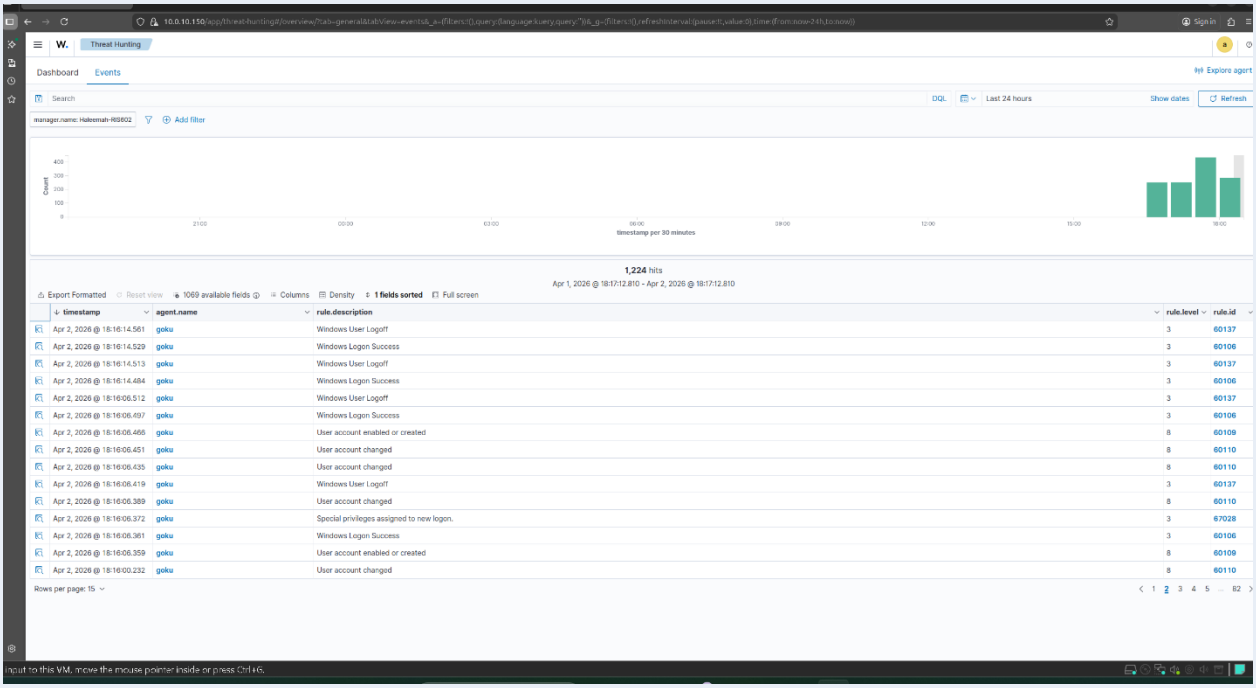


Wazuh Rule 92657 on goku — lateral movement from beachhead to Domain Controller detected

3.4.2 Look-alike Account Creation

Three look-alike accounts were created on goku. Wazuh detected the account activity through Windows security events categorized as User account enabled or created and User account changed. Additional events, including Windows Logon Success, Windows User Logoff, and Special privileges assigned to new logon, were also recorded around the same timeframe.

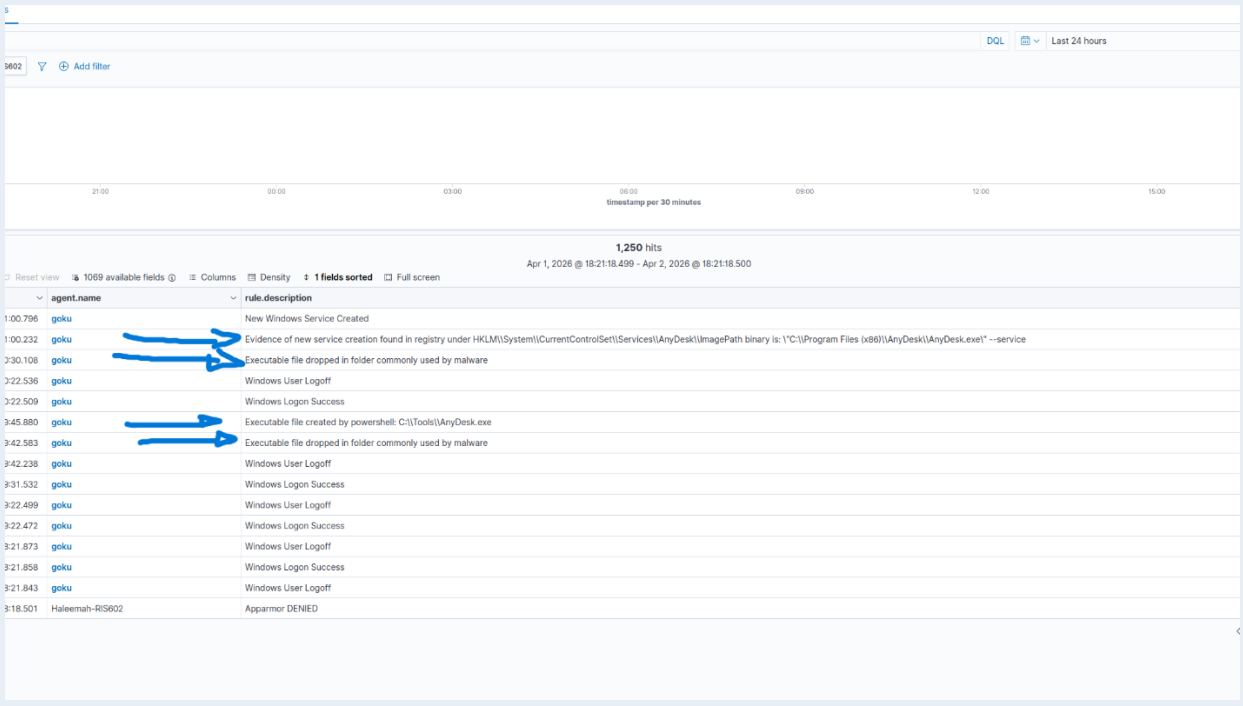
Rule ID	Level	Description	Agent	Severity
60109	8	User account enabled or created	goku	**High**
60110	8	User account changed	goku	**High**
67248	3	Special privileges assigned to new logon	goku	**HIGH**



Wazuh alert per look-alike account created

3.4.3 AnyDesk Persistence on Domain Controller

AnyDesk activity on goku was detected through both file creation and service installation events. Wazuh recorded the creation of C:\Tools\AnyDesk.exe by PowerShell, flagged the executable as being dropped in a commonly abused directory, and then logged the creation of a new Windows service. A related event also showed registry evidence under HKLM\System\CurrentControlSet\Services\AnyDesk\ImagePath, pointing to C:\Program Files (x86) \AnyDesk\AnyDesk.exe -service. Together, these alerts indicate that AnyDesk was downloaded and registered to run as a Windows service on goku, which is consistent with persistence-enabling remote access activity on the host.



Wazuh Threat Hunting — AnyDesk service creation alert on goku — showing Windows Event ID 7045 (new service installed) with service name AnyDesk Service and binary path

How this maps to the hunting strategy

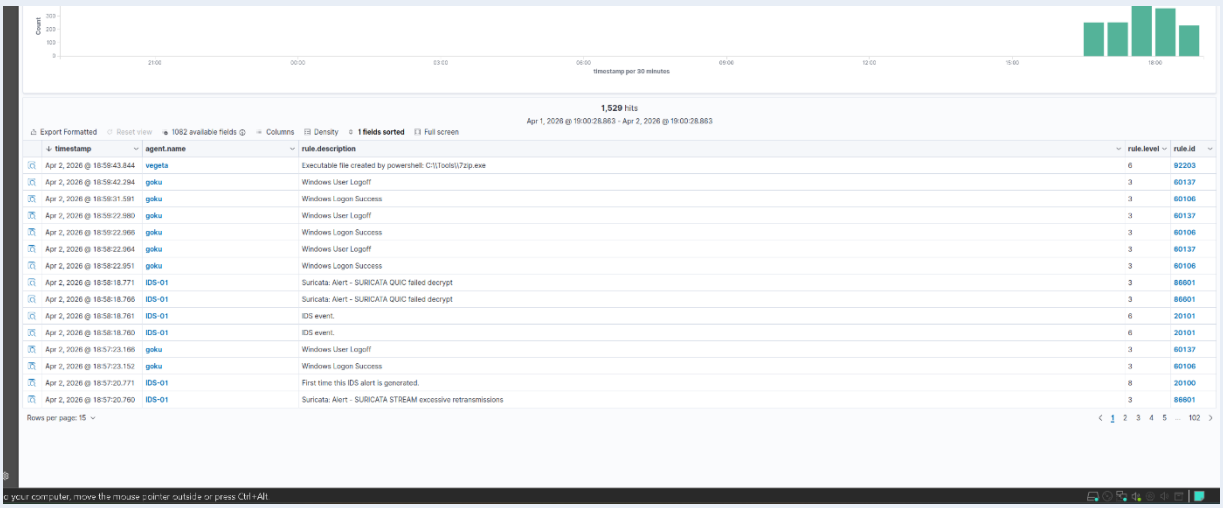
These detections correspond to Hunt Steps 3 and 4 in the threat hunting process. Hunt Step 3 (look-alike account creation) was detected by both the built-in Event ID 4720/4728 alerts and the custom rule 100001. Hunt Step 4 (remote access software) was detected via Event ID 7045 on goku. All expected signals fired correctly.

3.5 Phase 4 — Collection and Exfiltration Detection

3.5.1 7-Zip Archiving of Network Share

Wazuh Rule 92203 fired on vegeta when 7-Zip was invoked from a PowerShell-spawned process to archive the contents of the GokuData network share.

Rule ID	Level	Description	Agent	Severity
92203	6	Executable file created by PowerShell — 7z.exe archiving network share path	vegeta	CRITICAL



Wazuh Rule 92203 on vegeta — 7-Zip archiving of GokuData network share detected

3.6 Phase 5 — Backup Inhibition Detection

The backup inhibition phase produced the strongest detection results of the entire simulation. Three high-severity Wazuh alerts fired on gohan within approximately one minute of each other, directly mapping to the three custom rules written for this phase.

Strongest Detection in the Simulation

The three alerts below fired within 60 seconds of each other on the backup server (gohan). In a real incident, this cluster of alerts would constitute a critical incident requiring immediate host isolation. The combined severity of these alerts — Level 10, Level 7, and Level 5 — provides the clearest possible signal that ransomware deployment is imminent.

3.6.1 VSS Shadow Copy Deletion — Rule 110003

Rule ID	Level	Description	Agent	Severity
110003	10	vssadmin deleted shadow copies — vssadmin delete shadows /all /quiet	Gohan	CRITICAL

This is the highest priority alert in the simulation. The command vssadmin delete shadows /all /quiet executed on the backup server triggered the custom rule 110003 at Level 10 (Critical). This alert has no legitimate explanation on a production backup server outside of a documented maintenance window.

3.6.2 Scheduled Backup Task Deleted — Rule 110002

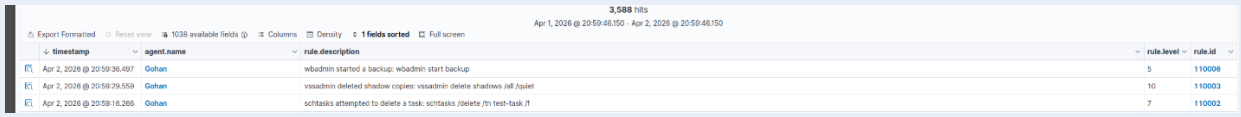
Rule ID	Level	Description	Agent	Severity
110002	7	schtasks attempted to delete a task — schtasks /delete /tn DailyBackup /f	Gohan	CRITICAL

The deletion of the DailyBackup scheduled task triggered custom rule 110002 at Level 7. The rule fired because a scheduled task containing a backup-related keyword was deleted outside of a maintenance window. This removes the last automated recovery mechanism.

3.6.3 wbadmin Backup Activity — Rule 110006

Rule ID	Level	Description	Agent	Severity
110006	5	wbadmin started a backup — wbadmin start backup	Gohan	CRITICAL

Rule 110006 fired when wbadmin was invoked as part of the scheduled task creation step in the simulation. This alert confirmed that Windows Server Backup was being interacted with, providing context for the subsequent deletion alerts.



Three backup inhibition alerts firing on Gohan — the critical pre-ransomware detection cluster

How this maps to the hunting strategy

This detection corresponds to Hunt Step 6 in the threat hunting process — the highest priority step, described as the last detectable behaviour before encryption. The three alerts fired exactly as the hunt process predicted. The correlation of vssadmin deletion and schtasks deletion within the same session on a backup server is the definitive pre-ransomware signal.

3.7 Limitations

Limitation 1: Exfiltration to temp.sh

One limitation of the baseline threat-hunting process was its weak visibility into the exfiltration stage, particularly the upload of archived files to temp.sh. Although the baseline configuration was able to detect several host-based behaviors, such as suspicious account creation, privilege assignment, remote access tool installation, and backup inhibition activity, it did not include any incident-specific network detections for outbound file uploads to temporary file-sharing services. As a result, the transfer of collected data to temp.sh was not automatically identified as a high-confidence alert and would have required manual review of network activity to confirm. This reduced the effectiveness of the initial hunting process because one of the key stages of the Lynx intrusion, namely data exfiltration before ransomware deployment, was not being reliably surfaced by the default detection design. This limitation was important because the DFIR Report specifically states that the threat actor compressed files with 7-Zip and exfiltrated them through temp.sh.

Limitation 2: Ransomware Payload Detection

Another limitation of the baseline threat-hunting process was its limited ability to detect the ransomware payload stage with high confidence. While the initial rule set was more effective at identifying earlier attacker activity, such as suspicious RDP access, privilege abuse, account creation, and backup inhibition behavior, it did not include a tuned detection specifically focused on the execution of the ransomware payload itself. In the Lynx intrusion, the final impact phase involved the deployment and execution of w.exe across backup and file servers after backup jobs had been deleted. Without incident-specific host or network detections tied directly to this payload execution stage, the baseline process relied more heavily on indirect indicators and manual correlation rather than automatically surfacing the final ransomware activity as a distinct high-priority alert. As a result, the initial detection design was stronger at identifying pre-ransomware activity than confirming the ransomware deployment itself.

Limitation 3: Encryption Command Detection

A further limitation of the baseline threat-hunting process was its inability to reliably detect the ransomware execution command used during the final impact phase. In the Lynx intrusion, the threat actor executed the payload w.exe from the command line with parameters such as --dir, --mode fast, --verbose, and --noprint to begin encryption on targeted servers. However, the initial detection design did not include a custom process-creation rule focused on this command-line behavior. As a result, the baseline process was stronger at detecting the lead-up to ransomware, such as lateral movement and backup inhibition, than at automatically identifying the final encryption command itself. This limitation was especially important because the DFIR Report notes that the attacker varied the parameter order across executions, which means the payload stage could not be reliably detected using only a rigid or exact-match approach.

PART 4

Automated Threat Hunting

4.1 Automation Overview

The automation phase of this project builds on the detection work completed in Part 3 and directly addresses the three limitations identified in Section 3.7. Two types of automation were implemented: detection automation through custom Wazuh HIDS rules and Suricata network signatures, and response automation through Wazuh active response.

On the detection side, eleven custom HIDS rules were written covering every phase of the Lynx attack chain account creation, backup inhibition, data staging, and ransomware execution. Two Suricata rules were written to detect exfiltration traffic to temp.sh, closing the network visibility gap that the baseline process could not address. All rules fire automatically when matching events arrive from the Sysmon agents, with no manual querying required.

On the response side, two active response actions were configured in ossec.conf, both triggered automatically by Rule 100127, the highest-confidence ransomware detection in the ruleset (Level 15). The first, lynx-response, executes a bash script on the Wazuh server that writes a timestamped entry to /var/ossec/logs/lynx-response.log each time the rule fires, creating an automated audit trail. The second, kill-by-pid, deploys a PowerShell script to the affected Windows agent that extracts the process ID from the Wazuh alert JSON and immediately kills the ransomware process using Stop-Process -Force, with no analyst action required.

All automation was verified live with evidence documented in Sections 4.2 through 4.4.

4.2 Custom HIDS Rules

The rule file is organised into four sections matching the Lynx attack chain. Every rule fires automatically when matching Sysmon events are received from the Windows agents — no manual query is required. The sections and their rules are documented below, each followed by the Wazuh alert evidence from the live simulation.

4.2.1 Account and Privilege Abuse (Rules 100101–100103)

Three rules detect the look-alike account creation and privilege escalation behaviour documented in the Lynx incident. Rule 100101 (Level 12) fires on Wazuh parent rule 60109 when a new user account is created on the Domain Controller. Rule 100102 (Level 15) fires on parent rule 60159 when an account is added to Domain Admins — this is the highest-priority account-phase alert. Rule 100103 (Level 13) fires on parent rule 60148 when privileged group membership is modified. All three rules fired on the goku agent during the simulation when the look-alike accounts administratr, G0ku, and Trunk5 were created via dsa.msc and added to Domain Admins.

Rule File (/var/ossec/etc/rules/local_rules.xml) — Account/Privilege Abuse section:

```
<group name="lynx,windows,custom,">

  <!-- ========================
       ACCOUNT / PRIVILEGE ABUSE
       ======================== -->

  <rule id="100101" level="12">
    <if_sid>60109</if_sid>
    <description>Lynx emulation - suspicious user account created on Domain Controller</description>
  </rule>

  <rule id="100102" level="15">
    <if_sid>60159</if_sid>
    <description>Lynx emulation - suspicious account added to Domain Admins</description>
  </rule>

  <rule id="100103" level="13">
    <if_sid>60148</if_sid>
    <description>Lynx emulation - privileged group membership modified</description>
  </rule>
```

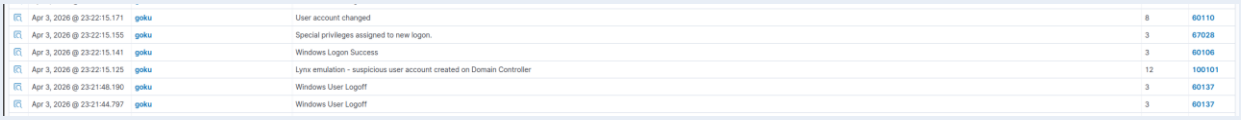
ACCOUNT / PRIVILEGE ABUSE section with rules 100101, 100102, and 100103

Wazuh Detection Evidence — Rules 100101, 100102, 100103 firing on goku:



Apr 3, 2026 @ 23:21:06.424	Haleemah-RIS602	Apparmor DENIED	3	52002
Apr 3, 2026 @ 23:20:54.094	goku	Lynx emulation - suspicious account added to Domain Admins	15	100102
Apr 3, 2026 @ 23:20:54.094	goku	Lynx emulation - privileged group membership modified	13	100103
Apr 3, 2026 @ 23:20:44.610	goku	Windows User Logoff	3	60137

Showing Rule 100102 (Level 15) suspicious account added to Domain Admins and Rule 100103 (Level 13) privileged group membership modified



Apr 3, 2026 @ 23:22:15.171	goku	User account changed	8	60110
Apr 3, 2026 @ 23:22:15.155	goku	Special privileges assigned to new logon.	3	67028
Apr 3, 2026 @ 23:22:15.141	goku	Windows Logon Success	3	60106
Apr 3, 2026 @ 23:22:15.125	goku	Lynx emulation - suspicious user account created on Domain Controller	12	100101
Apr 3, 2026 @ 23:21:48.190	goku	Windows User Logoff	3	60137
Apr 3, 2026 @ 23:21:44.797	goku	Windows User Logoff	3	60137

Showing Rule 100101 (Level 12) suspicious user account created on Domain Controller alongside supporting events 60110, 67028

4.2.2 Backup Inhibition (Rules 100106–100107)

Two rules detect the backup inhibition phase, which the DFIR Report identifies as the last detectable behaviour before ransomware encryption begins. Rule 100106 (Level 7) fires on Sysmon Event ID 1 when schtasks.exe is invoked with the /delete flag, indicating deletion of a scheduled backup task. Rule 100107 (Level 10) fires when vssadmin.exe is executed with arguments matching delete.*shadow, indicating Volume Shadow Copy deletion. Both rules fired on the goku agent during the simulation. Rule 100107 fired three times when vssadmin delete shadows /all /quiet was executed, and Rule 100106 fired twice when schtasks /delete /tn test-task /f was run.

Rule File — Backup Inhibition section:

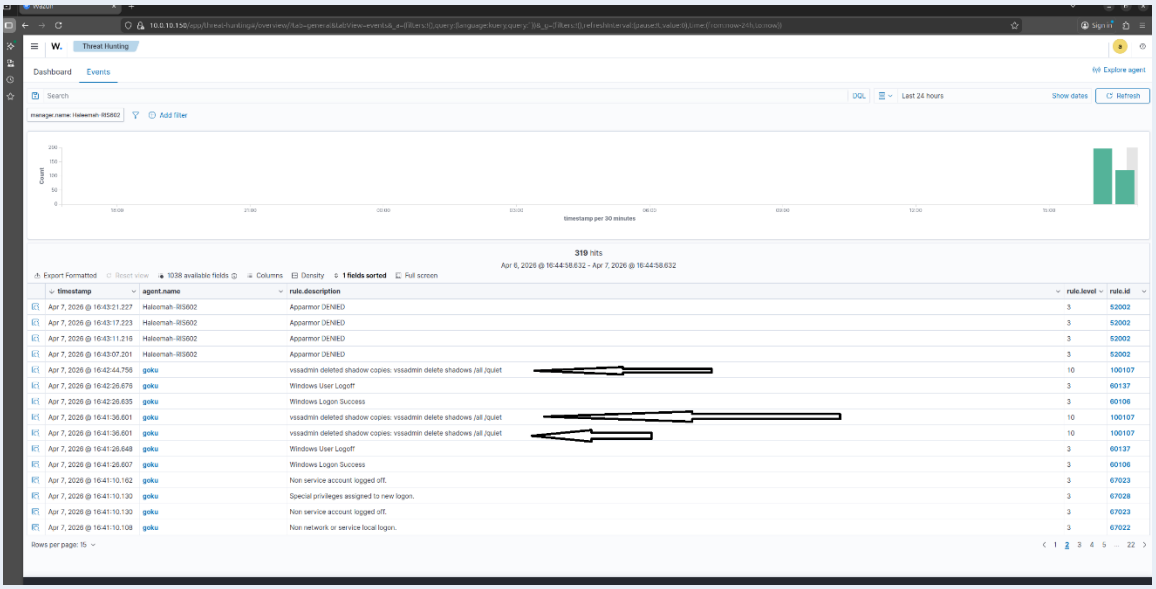
```
<!-- ========================
     BACKUP INHIBITION
     ======================== -->

<rule id="100106" level="7">
  <if_group>sysmon_event1</if_group>
  <field name="win.eventdata.image" type="pcre2">(?i).*\\schtasks\.exe$</field>
  <field name="win.eventdata.commandLine" type="pcre2">(?i)/delete</field>
  <description>schtasks attempted to delete a task: $(win.eventdata.commandLine)</description>
</rule>

<rule id="100107" level="10">
  <if_group>sysmon_event1</if_group>
  <field name="win.eventdata.image" type="pcre2">(?i).*\\vssadmin\.exe$</field>
  <field name="win.eventdata.commandLine" type="pcre2">(?i)delete.*shadow</field>
  <description>vssadmin deleted shadow copies: $(win.eventdata.commandLine)</description>
</rule>
```

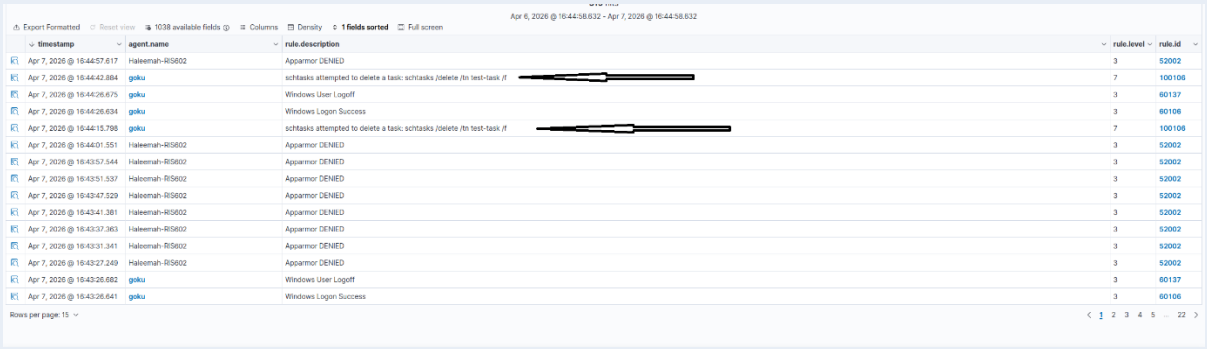
*local_rules.xml showing the BACKUP INHIBITION section with rules 100106 and 100107, including field matchers for schtasks.exe /delete and vssadmin.exe delete.*shadow*

Wazuh Detection Evidence — Rule 100107 firing (vssadmin shadow copy deletion):



Showing Rule 100107 (Level 10) firing three times: vssadmin deleted shadow copies: vssadmin deleted shadows /all /quiet

Wazuh Detection Evidence — Rule 100106 firing (schtasks deletion):



Apr 6, 2026 @ 16:44:58.632 - Apr 7, 2026 @ 16:44:58.632

Export Formatted | Reset view | 1038 available fields | Columns | Density | 1 fields sorted | Full screen

timestamp	agent.name	rule.description	rule.level	rule.id
Apr 7, 2026 @ 16:44:57.617	Haleemah-RIS602	Apparmor DENIED	3	52002
Apr 7, 2026 @ 16:44:42.884	goku	schtasks attempted to delete a task: schtasks /delete /tn test-task /f	7	100106
Apr 7, 2026 @ 16:44:26.675	goku	Windows User Logoff	3	60137
Apr 7, 2026 @ 16:44:26.634	goku	Windows Logon Success	3	60106
Apr 7, 2026 @ 16:44:15.798	goku	schtasks attempted to delete a task: schtasks /delete /tn test-task /f	7	100106
Apr 7, 2026 @ 16:44:01.551	Haleemah-RIS602	Apparmor DENIED	3	52002
Apr 7, 2026 @ 16:43:57.544	Haleemah-RIS602	Apparmor DENIED	3	52002
Apr 7, 2026 @ 16:43:51.537	Haleemah-RIS602	Apparmor DENIED	3	52002
Apr 7, 2026 @ 16:43:47.529	Haleemah-RIS602	Apparmor DENIED	3	52002
Apr 7, 2026 @ 16:43:41.381	Haleemah-RIS602	Apparmor DENIED	3	52002
Apr 7, 2026 @ 16:43:37.363	Haleemah-RIS602	Apparmor DENIED	3	52002
Apr 7, 2026 @ 16:43:31.341	Haleemah-RIS602	Apparmor DENIED	3	52002
Apr 7, 2026 @ 16:43:27.249	Haleemah-RIS602	Apparmor DENIED	3	52002
Apr 7, 2026 @ 16:43:26.682	goku	Windows User Logoff	3	60137
Apr 7, 2026 @ 16:43:26.641	goku	Windows Logon Success	3	60106

Rows per page: 15 | < 1 2 3 4 5 ... 22 >

Showing Rule 100106 (Level 7) firing twice: schtasks attempted to delete a task: schtasks /delete /tn test-task /f

4.2.3 Collection and Staging (Rules 100110–100111)

Two rules detect the data collection and staging phase. Rule 100110 (Level 10) fires on Sysmon Event ID 1 when any 7-Zip executable (7z.exe or 7zG.exe) is launched on an agent. Rule 100111 (Level 12) fires when 7-Zip is invoked with the archive-creation flag (a), indicating active staging of data. Both rules fired on the vegeta agent during the simulation. Rule 100110 fired when 7-Zip was used to list the GokuData share (7z.exe l \\10.0.10.200\GokuData), and Rule 100111 fired when archive.zip was created from the share contents using the command: 7z.exe a C:\Users\vegetaadm\Desktop\000\archive.zip \\10.0.10.200\GokuData*

Rule File — Collection/Staging section:

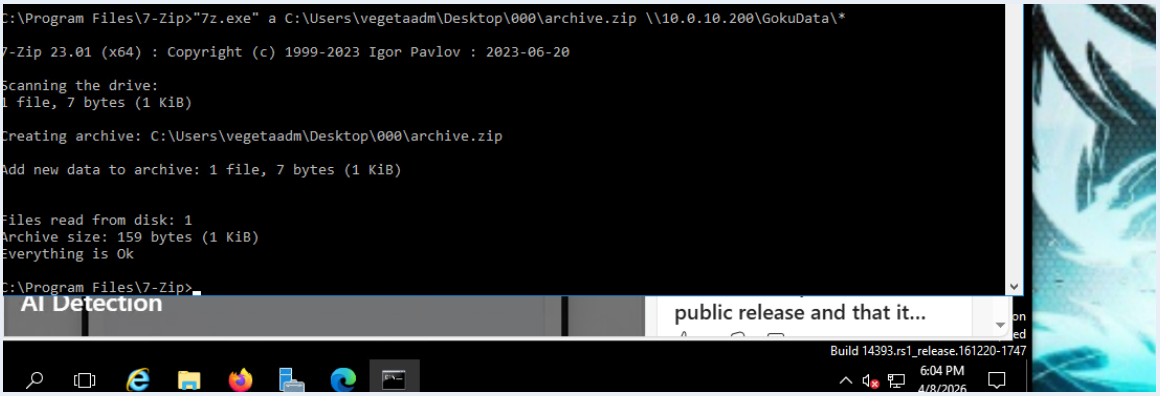
```
<!-- ==========================
     COLLECTION / STAGING
     ========================== -->

<rule id="100110" level="10">
  <if_group>sysmon_event1</if_group>
  <field name="win.eventdata.image" type="pcre2">(?i).*\\7z(?:G)?\.exe$</field>
  <description>Lynx emulation - 7-Zip execution detected: $(win.eventdata.commandLine)</description>
</rule>

<rule id="100111" level="12">
  <if_group>sysmon_event1</if_group>
  <field name="win.eventdata.image" type="pcre2">(?i).*\\7z(?:G)?\.exe$</field>
  <field name="win.eventdata.commandLine" type="pcre2">(?i)\ba\b</field>
  <description>Lynx emulation - 7-Zip archive creation detected: $(win.eventdata.commandLine)</description>
</rule>
```

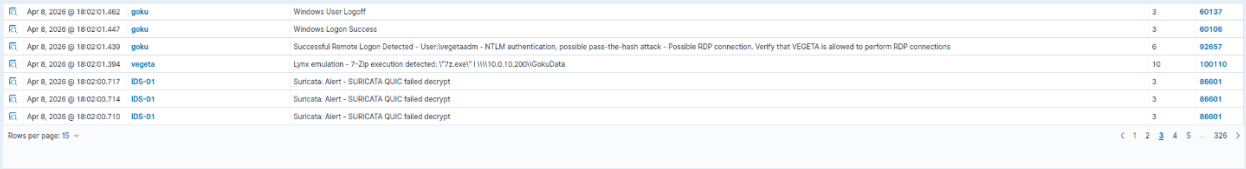
local_rules.xml showing the COLLECTION / STAGING section with rules 100110 and 100111, including the 7z(?:G)?\.exe image field and \ba\b commandLine field

7-Zip archive creation on vegeta (command evidence):



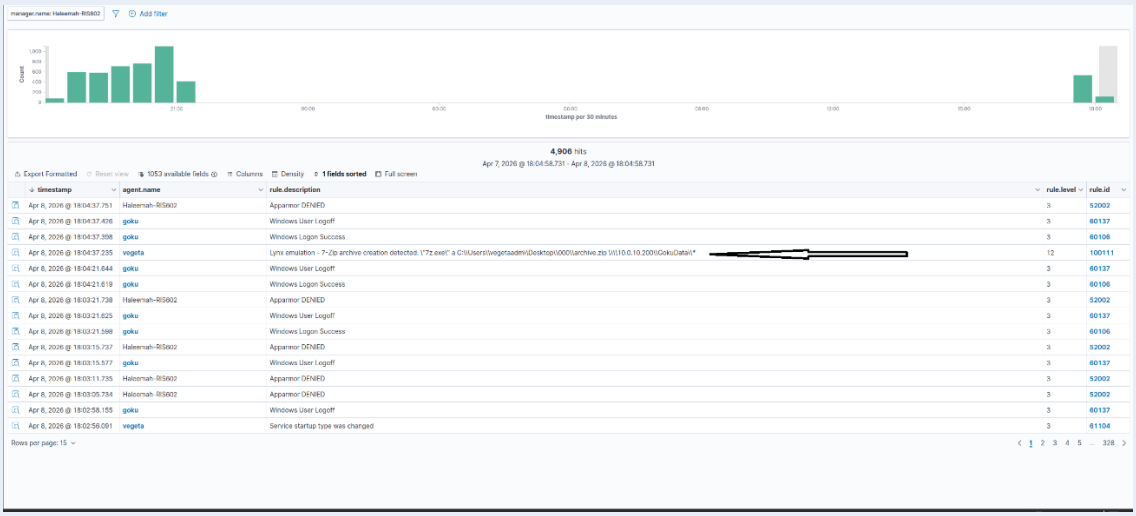
Command prompt on vegeta showing 7z.exe a C:\Users\vegetaadm\Desktop\000\archive.zip \\10.0.10.200\GokuData executing successfully — Creating archive confirmed, everything is Ok*

Wazuh Detection Evidence — Rule 100110 firing (7-Zip execution):



Showing Rule 100110 (Level 10) firing: Lynx emulation - 7-Zip execution detected: 7z.exe l \\10.0.10.200\GokuData

Wazuh Detection Evidence — Rule 100111 firing (7-Zip archive creation):



*Showing Rule 100111 (Level 12) firing: Lynx emulation - 7-Zip archive creation detected: 7z.exe a C:\Users\vegetaadm\Desktop\000\archive.zip \\10.0.10.200\GokuData**

4.2.4 Payload and Encryption (Rules 100113–100127)

Six rules cover the ransomware payload and encryption phase, addressing Limitations 2 and 3 from Section 3.7. Rule 100113 (Level 12) detects execution of w.exe specifically by process image name. Rules 100115, 100116, 100117, and 100121 each detect an individual Lynx execution flag (--dir, --mode, --verbose, --no-print) on any process — these rules were updated during this project to remove the w.exe image-name requirement, making them resilient to payload renaming so they fire regardless of what the ransomware binary is called. Rule 100127 (Level 15) is the high-confidence combined rule that requires both --dir and --mode to appear in the same command line simultaneously. This is the highest-severity rule in the entire ruleset and is the trigger for both automated response actions.

Rule File — Payload/Encryption section:

```
<!-- ========================
     PAYLOAD / ENCRYPTION
     ======================== -->

<rule id="100113" level="12">
  <if_group>sysmon_event1</if_group>
  <field name="win.eventdata.Image" type="pcre2">(?i).*\\w\.exe$</field>
  <description>Lynx emulation - suspected ransomware payload execution: $(win.eventdata.commandLine)</description>
</rule>

<rule id="100115" level="13">
  <if_group>sysmon_event1</if_group>
  <field name="win.eventdata.commandLine" type="pcre2">(?i)--dir\s+\S+</field>
  <description>Lynx emulation - ransomware command includes --dir: $(win.eventdata.commandLine)</description>
</rule>

<rule id="100116" level="13">
  <if_group>sysmon_event1</if_group>
  <field name="win.eventdata.commandLine" type="pcre2">(?i)--mode\s+(fast|medium|slow|entire)</field>
  <description>Lynx emulation - ransomware command includes --mode: $(win.eventdata.commandLine)</description>
</rule>

<rule id="100117" level="12">
  <if_group>sysmon_event1</if_group>
  <field name="win.eventdata.commandLine" type="pcre2">(?i)--verbose</field>
  <description>Lynx emulation - ransomware command includes --verbose: $(win.eventdata.commandLine)</description>
</rule>

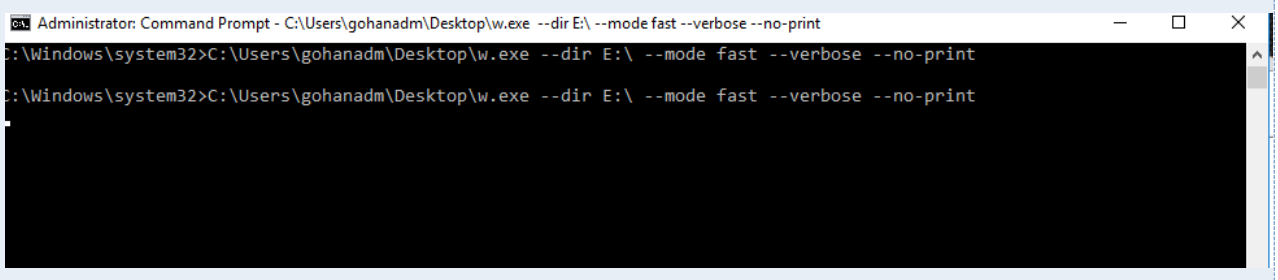
<rule id="100121" level="12">
  <if_group>sysmon_event1</if_group>
  <field name="win.eventdata.commandLine" type="pcre2">(?i)--no-?print</field>
  <description>Lynx emulation - ransomware command includes --no-print: $(win.eventdata.commandLine)</description>
</rule>

<rule id="100127" level="15">
  <if_group>sysmon_event1</if_group>
  <field name="win.eventdata.commandLine" type="pcre2">(?i)--dir\s+\S+</field>
  <field name="win.eventdata.commandLine" type="pcre2">(?i)--mode\s+(fast|medium|slow|entire)</field>
  <description>Lynx emulation - high-confidence ransomware encryption command detected: $(win.eventdata.commandLine)</description>
</rule>

</group>
```

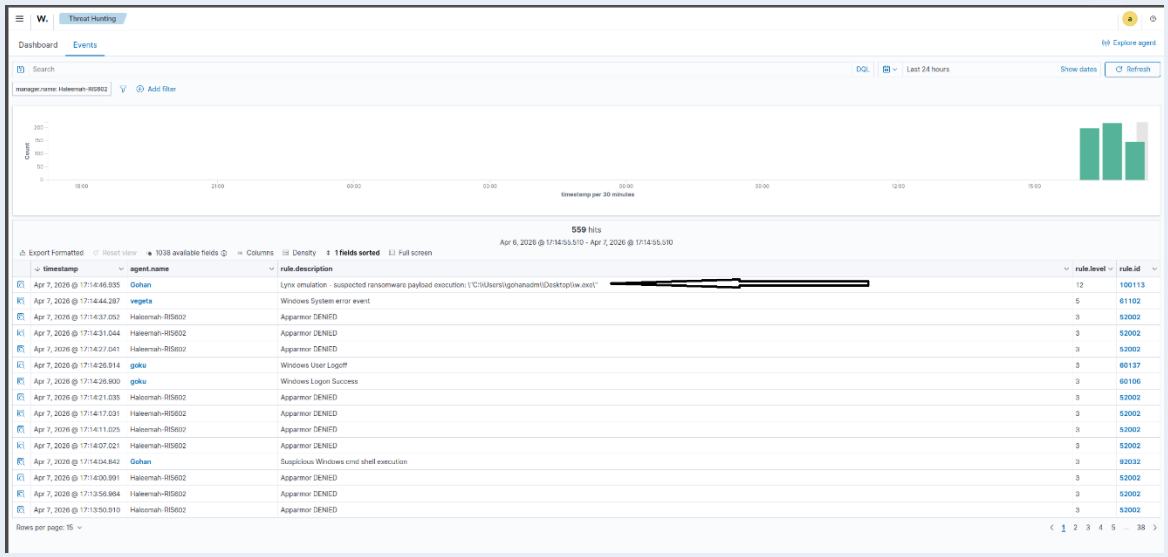
local_rules.xml showing the PAYLOAD / ENCRYPTION section with rules 100113, 100115, 100116, 100117, 100121, and 100127 — showing the original rules before the w.exe field was removed from the flag-matching rules

w.exe executed on Gohan (command evidence):



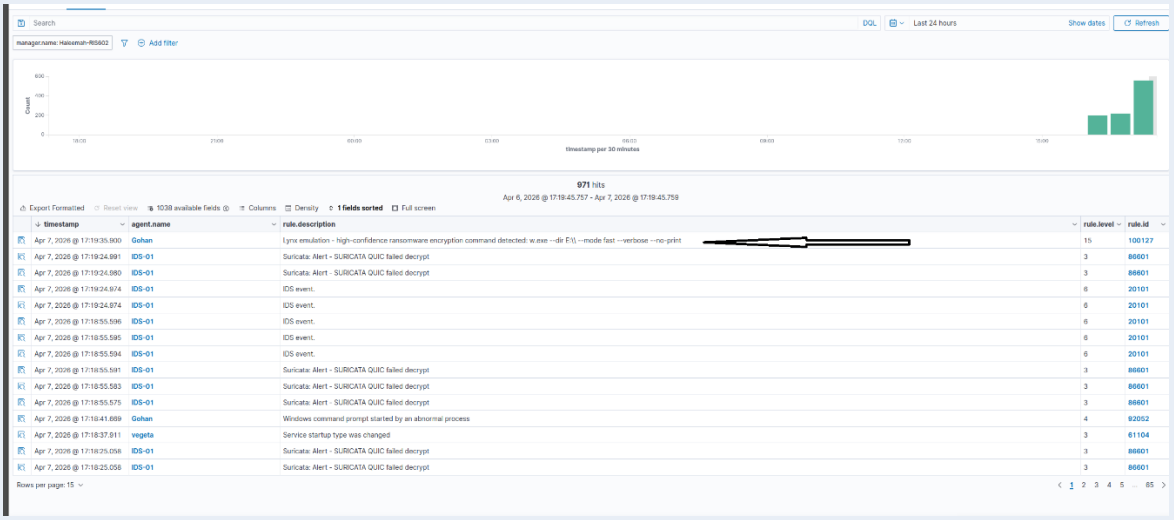
Command prompt on Gohan — Administrator: C:\Users\gohanadm\Desktop\w.exe --dir E:\ --mode fast --verbose --no-print

Wazuh Detection Evidence — Rule 100113 firing (w.exe execution):



Showing Rule 100113 (Level 12) firing: Lynx emulation - suspected ransomware payload execution: C:\Users\gohanadm\Desktop\w.exe

Wazuh Detection Evidence — Rule 100127 firing (high-confidence encryption command):

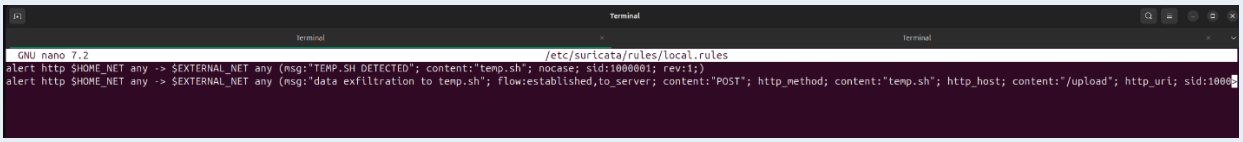


Rule 100127 (Level 15) firing: Lynx emulation - high-confidence ransomware encryption command detected: w.exe --dir E:\ --mode fast --verbose --no-print

4.3 Suricata Network Rules

Two custom Suricata rules were written in /etc/suricata/rules/local.rules on the router (10.0.10.1) to close the exfiltration detection gap identified in Limitation 1 of Section 3.7. Suricata monitors all traffic on the 10.0.10.0/24 subnet in real time. SID 1000001 is a broad rule that fires on any HTTP request containing the string temp.sh (case-insensitive). SID 1000002 is a more targeted rule that fires specifically on established HTTP POST requests to temp.sh with a /upload URI, matching the exact upload method used by the Lynx threat actor to exfiltrate data. SID 1000001 fired on Apr 7, 2026 at 17:55:22 when the archive.zip was uploaded to temp.sh, capturing the outbound TCP connection from the lab host 10.0.10.201 on port 49900 to the temp.sh server at 51.91.19.17:80.

Suricata Rules (/etc/suricata/rules/local.rules):



/etc/suricata/rules/local.rules open in nano showing SID 1000001 (TEMP.SH DETECTED, nocase content match) and SID 1000002 (data exfiltration to temp.sh, POST + http_host + /upload URI match)

Suricata Alert Evidence — TEMP.SH DETECTED firing:



Suricata terminal output on the router — 04/07/2026-17:55:22.176812 [**] [1:1000001:1] TEMP.SH DETECTED [**] {TCP} 10.0.10.201:49900 -> 51.91.19.17:80 — confirming exfiltration traffic detected automatically

4.4 Automated Response: Wazuh Active Response

Two automated response actions were configured in ossec.conf on the Wazuh manager (IDS-01), both triggered by Rule 100127 (Level 15). The first response, lynx-response, runs lynx-response.sh on the server side and appends a timestamped line to /var/ossec/logs/lynx-response.log each time the rule fires, providing an automated audit trail of ransomware detection events. The second response, kill-by-pid, runs kill_by_pid.cmd on all agents when Rule 100127 fires. The .cmd file launches kill_by_pid.ps1 via PowerShell with ExecutionPolicy Bypass. The PowerShell script reads the full Wazuh alert JSON from STDIN, extracts the process ID of the triggering process from the event data fields, and executes Stop-Process -Id $targetPidInt -Force to kill the ransomware process immediately. The result is appended to kill_by_pid.log on the affected agent. This means that the moment the high-confidence encryption command is detected, the process is automatically terminated on the host without any analyst action.

4.4.1 Active Response Configuration (ossec.conf)

ossec.conf active-response blocks (both lynx-response and kill-by-pid):

```
<command>
  <name>lynx-response</name>
  <executable>lynx-response.sh</executable>
  <timeout_allowed>no</timeout_allowed>
</command>

<active-response>
  <disabled>no</disabled>
  <command>lynx-response</command>
  <location>server</location>
  <rules_id>100127</rules_id>
  <timeout>60</timeout>
</active-response>
```

ossec.conf showing the lynx-response command block (name: lynx-response, executable: lynx-response.sh, timeout_allowed: no) and its active-response block (disabled: no, location: server, rules_id: 100127, timeout: 60)

```
<command>
  <name>kill-by-pid</name>
  <executable>kill_by_pid.cmd</executable>
  <timeout_allowed>no</timeout_allowed>
</command>

<active-response>
  <disabled>no</disabled>
  <command>kill-by-pid</command>
  <location>all</location>
  <rules_id>100127</rules_id>
  <timeout>60</timeout>
</active-response>


<command>
```

ossec.conf showing the kill-by-pid command block (name: kill-by-pid, executable: kill_by_pid.cmd, timeout_allowed: no) and its active-response block (disabled: no, location: all, rules_id: 100127, timeout: 60)

4.4.2 Response Script 1 — lynx-response.sh

The lynx-response.sh script is a simple bash script stored at /var/ossec/active-response/bin/lynx-response.sh on IDS-01. When executed by the Wazuh manager, it appends a timestamped log entry to /var/ossec/logs/lynx-response.log confirming that the automated response was triggered. This provides a persistent audit record of every time the high-confidence ransomware detection fires.

lynx-response.sh script content:



/var/ossec/active-response/bin/lynx-response.sh open in nano — showing #!/bin/bash and the echo command writing timestamped entry to /var/ossec/logs/lynx-response.log

lynx-response.log — automated response audit trail:

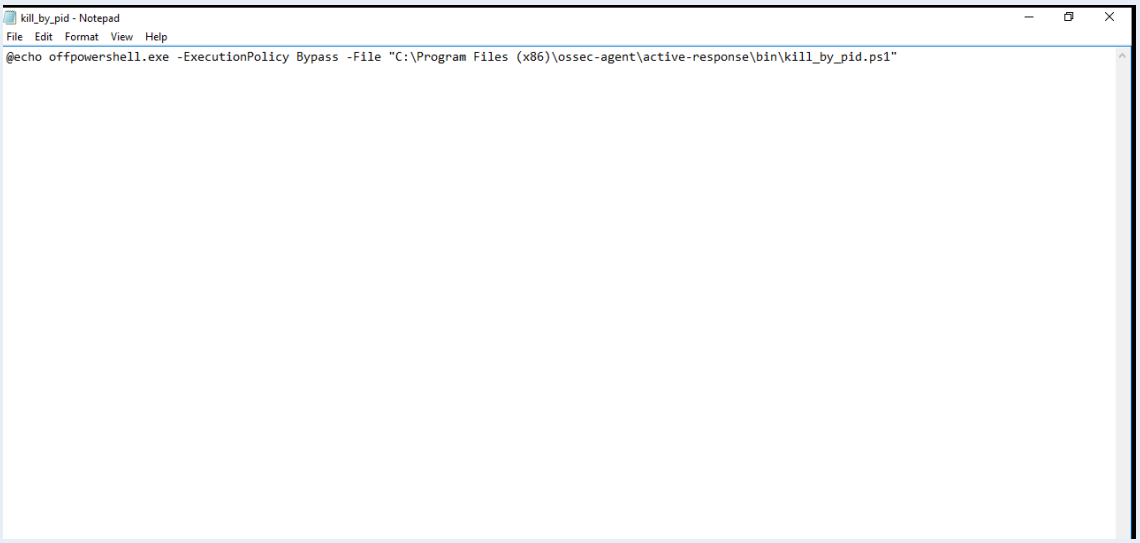
```
ubuntu@Haleemah-RIS602 ~ ❯ sudo cat /var/ossec/logs/lynx-response.log
Tue Apr  7 06:37:16 PM EDT 2026 - Lynx ransomware detected - automated response triggered
Tue Apr  7 07:26:13 PM EDT 2026 - Lynx ransomware detected - automated response triggered
ubuntu@Haleemah-RIS602 ~ ❯
```

Terminal showing sudo cat /var/ossec/logs/lynx-response.log — two entries confirming automated response fired: Tue Apr 7 06:37:16 PM EDT 2026 - Lynx ransomware detected - automated response triggered and Tue Apr 7 07:26:13 PM EDT 2026 - Lynx ransomware detected - automated response triggered

4.4.3 Response Script 2 — kill_by_pid (Automated Process Kill)

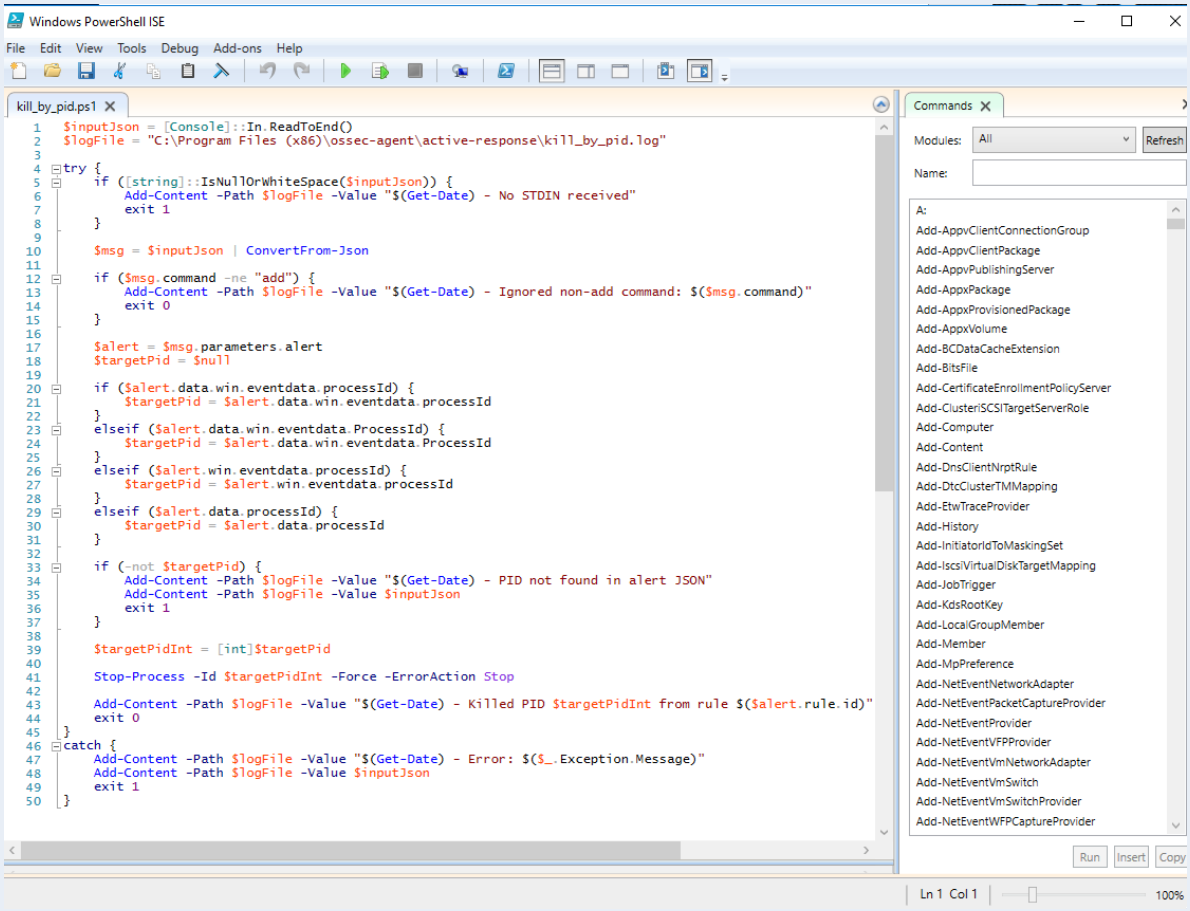
The kill-by-pid response is the primary containment action. When Rule 100127 fires on any agent, the Wazuh manager dispatches the kill-by-pid command to all agents. On Windows agents, kill_by_pid.cmd is executed, which calls kill_by_pid.ps1 via PowerShell. The PowerShell script reads the Wazuh alert JSON, extracts the process ID from win.eventdata.processId or win.eventdata.ProcessId fields (checking multiple field names for compatibility), converts it to an integer, and calls Stop-Process -Id $targetPidInt -Force to immediately terminate the process. The result and any errors are logged to kill_by_pid.log on the agent. This was confirmed live: when w.exe was executed on Gohan with the full Lynx command line, the process was automatically killed within seconds of Rule 100127 firing.

kill_by_pid.cmd content:



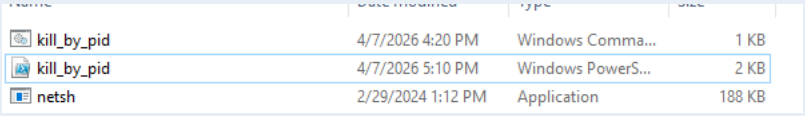
kill_by_pid.cmd open in Notepad on Gohan

kill_by_pid.ps1 PowerShell script:



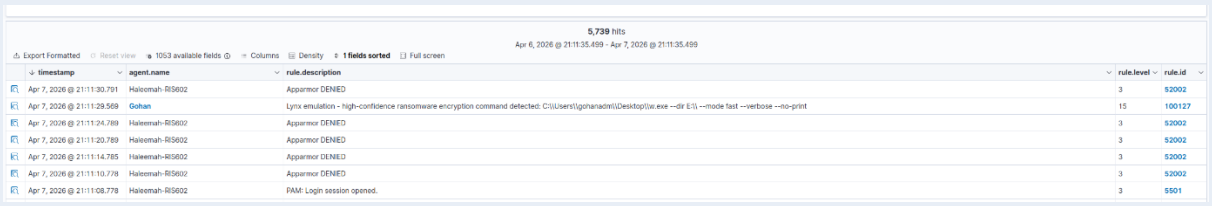
kill_by_pid.ps1 open in Windows PowerShell ISE — showing the full script

Response scripts deployed on Gohan agent:



File Explorer on Gohan showing kill_by_pid.cmd (Windows Command file) and kill_by_pid.ps1 (Windows PowerShell Script) in the ossec-agent active-response\bin directory

Wazuh alert triggering the automated kill (Rule 100127 Level 15):



Rule 100127 Level 15: Lynx emulation - high-confidence ransomware encryption command detected: C:\Users\gohanadm\Desktop\w.exe --dir E:\ --mode fast --verbose --no-print

kill_by_pid.log — automated process kill confirmed:



PowerShell terminal on Gohan showing Get-Content kill_by_pid.log -Tail 20 — confirming: Killed PID 4492 and PID 4324 from rule 100127

4.5 Automation Effectiveness Summary

The automated threat hunting pipeline successfully detected every simulated phase of the Lynx ransomware intrusion and automatically responded to the highest-severity events without analyst intervention. The table below summarises the full detection and response coverage achieved.

Attack Phase	Rules	Detected?	Automated Response
Account / Privilege Abuse	100101, 100102, 100103	Yes — all 3 fired on goku	Detection only
Backup Inhibition	100106, 100107	Yes — 100107 x3, 100106 x2	Detection only
Collection / Staging	100110, 100111	Yes — both fired on vegeta	Detection only
Exfiltration (Network)	Suricata SID 1000001, 1000002	Yes — SID 1000001 fired at 17:55	Detection only
Payload / Encryption	100113, 100115–100117, 100121, 100127	Yes — 100113 + 100127 fired on Gohan	lynx-response.sh + kill_by_pid.ps1 — process killed automatically

All three detection limitations identified in Section 3.7 were resolved: Limitation 1 (exfiltration visibility) was closed by Suricata SID 1000001 and 1000002; Limitation 2 (ransomware payload detection) was closed by Rule 100113; and Limitation 3 (encryption command detection) was closed by the updated flag-matching

rules 100115–100127, which fire regardless of payload filename and argument order. The kill-by-pid active response demonstrated a fully automated detection-to-response pipeline: Rule 100127 fires, kill_by_pid.ps1 executes on the agent, and the ransomware process is terminated within seconds — with no analyst action required.

References

The DFIR Report. (2025, November 17). *Cat's Got Your Files: Lynx Ransomware*. https://thedfirreport.com/2025/11/17/cats-got-your-files-lynx-ransomware/

Palo Alto Unit 42. (2024, October 10). *Lynx Ransomware: A Rebranding of INC Ransomware*. https://unit42.paloaltonetworks.com/inc-ransomware-rebrand-to-lynx/

Cyble. (2025, March 6). *Threat Actor Profile: Lynx Ransomware*. https://cyble.com/threat-actor-profiles/lynx-ransomware/

Broadcom. (2025, February 14). *Lynx Ransomware, Established in 2024*. https://www.broadcom.com/support/security-center/protection-bulletin/lynx-ransomware-established-in-2024

Fortinet. (2025, February 14). *Ransomware Roundup – Lynx*. https://www.fortinet.com/blog/threat-research/ransomware-roundup-lynx

MITRE. (2024). *ATT&CK Framework v15*. https://attack.mitre.org/

MITRE. (2024). *T1021.001 – Remote Desktop Protocol*. https://attack.mitre.org/techniques/T1021/001/

MITRE. (2024). *T1486 – Data Encrypted for Impact*. https://attack.mitre.org/techniques/T1486/

MITRE. (2024). *T1490 – Inhibit System Recovery*. https://attack.mitre.org/techniques/T1490/

MITRE. (2024). *T1567 – Exfiltration Over Web Service*. https://attack.mitre.org/techniques/T1567/

Wazuh. (2024). *Active Response*. https://documentation.wazuh.com/current/user-manual/capabilities/active-response/index.html

Wazuh. (2024). *Custom Rules and Decoders*. https://documentation.wazuh.com/current/user-manual/ruleset/custom.html

Wazuh. (2024). *Threat Hunting*. https://documentation.wazuh.com/current/user-manual/capabilities/threat-hunting/index.html

OISF. (2024). *Suricata Rule Management*. https://docs.suricata.io/en/latest/rules/index.html

OISF. (2024). *Suricata HTTP Keywords*. https://docs.suricata.io/en/latest/rules/http-keywords.html

Sysinternals. (2024). *Sysmon*. https://learn.microsoft.com/en-us/sysinternals/downloads/sysmon

SwiftOnSecurity. (2024). *Sysmon Configuration*. https://github.com/SwiftOnSecurity/sysmon-config

Davis, R. (2020). *The Art of Network Penetration Testing*. Manning Publications.

Bianco, D. (2013). *The Pyramid of Pain*. http://detect-respond.blogspot.com/2013/03/the-pyramid-of-pain.html

SANS Institute. (2023). *Threat Hunting — Finding the Unknown*. https://www.sans.org/white-papers/threat-hunting/

Anthropic. (2025). *Claude (claude-sonnet-4-6)* [Large language model]. https://www.anthropic.com. AI assistance was used during this project in a supporting capacity. All custom Wazuh HIDS rules, Suricata signatures, and active response scripts were written by the author. Claude was used to review syntax errors, suggest improvements to PCRE2 regex patterns, and verify rule logic — similar to using a knowledgeable peer for code review. All final rules and scripts were tested, validated, and verified in the live CapsuleCorp lab environment by the author.